# CISSP Domain 7｜セキュリティ運用 — 7.1〜7.15 統合マスター学習ノート

> **更新：2026-10-27**｜単一マスターファイル・全文更新方式
>
> **構成方針**：アップロードされた既存Markdownを**原則全文保持**し、会話で読み上げられた7.3・7.8、および7.12〜7.15を補完して統合。既存メモの具体例、比較表、確認問題を省略しない。
>
> **出典の区別**：7.1〜7.2、7.4〜7.7、7.9〜7.11は**添付ノート収録**。7.3・7.8は**当会話の読み上げから再構成**（元ノート未添付）。7.12〜7.15は**当会話の読み上げ内容＋明示した学習用補足**。このノートは元教材の逐語的複製ではなく、試験対策用の整理。
>
> **重要**：個々の規格・条項の版、法令の適用要件、製品の実装は時点・地域・環境に依存。既存ノートの記述は統合に際し全面的な外部検証を行ったものではない。

## 目次と収録状況

| 範囲 | 内容 | 根拠 |
|---|---|---|
| 7.1〜7.2 | 調査、フォレンジック、ログ、IDS/IPS、SIEM/SOAR、ISCM、DLP、UEBA | 添付Markdown |
| 7.3 | 構成管理・CI・各種ベースライン・CMB/CCB | 会話から再構成 |
| 7.4 | 最小権限・Need-to-Know・SoD・PAM・SLA | 添付Markdown |
| 7.5 | メディア保護・NIST SP 800-53 MP・サニタイズ | 添付Markdown |
| 7.6 | インシデント対応・ISO 27035・フォレンジック・RCA | 添付Markdown |
| 7.7 | NGFW・許可/拒否・外部委託・Sandbox・マルウェア・AI | 添付Markdown |
| 7.8 | パッチ・脆弱性管理、課題5点、適用10ステップ | 会話から再構成 |
| 7.9 | 変更管理・ITIL 4・RFC・リリース・デプロイ | 添付Markdown |
| 7.10 | バックアップ・サイト・HA・RAID 0〜6/01/10/15/51・SAN/NAS | 添付Markdown |
| 7.11 | BCDR発動・体制・連絡・復元・教訓 | 添付Markdown |
| 7.12 | リードスルー・机上・ウォークスルー・模擬・並行・完全中断 | 会話＋補足 |
| 7.13 | BCP・BIA・MTD/RTO/RPO/WRT・NIST 800-34・ISO 22301 | 会話＋補足 |
| 7.14 | 物理境界・内部コントロール・各種センサー | 会話＋補足 |
| 7.15 | 出張・脅迫・教育・2FA・SNS・内部脅威・緊急管理・MDM | 会話＋補足 |

## 最優先・横断比較

| 題材 | 一文で区別 |
|---|---|
| IDS / IPS | 見つける／検知して阻止する |

| 題材 | 一文で区別 |
|---|---|
| SIEM / SOAR | イベント収集・相関分析／対応連携・自動化 |
| 構成／脆弱性／パッチ／変更 | 現状態を把握／弱点を評価／修正を導入／変更の承認・統制 |
| 封じ込め／根絶／復旧／修復 | 拡大停止／攻撃手段除去／安全にサービス再開／弱点是正 |
| RAID／バックアップ | ディスク故障対策／過去時点に復元する仕組み |
| BCP／DRP | 重要業務の継続／ITシステム・データ復旧 |
| MTD／RTO／RPO | 停止許容限界／復旧完了の目標時間／許容データ損失幅 |
| パラレル／完全中断試験 | 本番を維持し代替側を検証／実際に本番を切替 |
| 境界／内部セキュリティ | 保護区域への侵入防止／区域内の移動・資産へのアクセス制御 |

# CISSP Domain 7｜セキュリティ運用：7.1〜7.2 統合学習ノート

> **対象**：音声で読み上げた **7.1 調査の理解と遵守、7.2 ロギングおよびモニタリング**
> **編集日**：2026年10月27日｜**形式**：試験対策用・比較／具体例／判断の観点を重視
> **注**：このノートは会話中の読み上げ内容を再構成し、公的資料で確認できた箇所を補足したもの。教材原文の逐語転記ではない。教材の一部訳語・表現は音声からの推定であり、疑義は注記した。**7.3以降は未収録。**

## 最初に覚える：超圧縮マップ

| 試験の論点 | 即答したい要点 |
|---|---|
| 調査で最優先 | **証拠の完全性・信頼性と適法性**を守る。調査対象者の権利も尊重 |
| Chain of Custody | 証拠を**誰が／いつ／どこで／何のために扱い、誰へ渡したか**の連続記録 |
| デジタルフォレンジック | 証拠を**特定 → 収集・保全 → 分析 → 報告**。可能な限り原本保全、コピー解析 |
| Event / Incident | **イベント≠インシデント**。イベントは観測された活動、インシデントは対応すべき事象 |
| Precursor / Indicator / IoC | **前兆／発生中・発生後の兆候／侵害を示唆する具体的な技術的痕跡** |
| IDS / IPS | **検知・通知／検知＋遮断**。IPSは誤遮断による可用性リスクあり |
| HIDS・HIPS / NIDS・NIPS | **ホスト上の活動／ネットワーク通信**を対象とする |
| Signature / Anomaly | **既知の攻撃特徴／通常からの逸脱**。前者は未知攻撃、後者は誤検知が課題 |
| Threat Hunting | アラートを待たず**仮説を立てて潜在脅威を探す**能動的な活動 |
| MITRE ATT&CK | 攻撃者の**Tactics（なぜ）・Techniques（どうやって）・Procedures（具体的実装）** |

| 試験の論点 | 即答したい要点 |
|---|---|
| SIEM / SOAR | **ログを集めて分析・相関・検知／複数ツールを連携して対応を自動化** |
| UEBA | **ユーザー・端末などの通常行動との差**からリスクを評価。異常＝侵害確定ではない |
| ISCM | **戦略定義 → プログラム確立 → 実装 → 分析・報告 → 対応 → 見直し・更新** |
| Ingress / Egress | **入ってくる通信の監視／出ていく通信・情報持ち出しの監視** |
| DLP | **保存中・移動中・使用中**の機密データの検出・監視・制御 |
| 監視の限界 | ログ改ざん、低速攻撃、暗号化・クラウド可視性、誤検知など。**人と運用設計**が不可欠 |

# 7.1 調査を理解し、遵守する

## 7.1.1 調査の完全性と倫理

**最重要原則：調査が社内処分・訴訟・刑事事件に進むかにかかわらず、調査そのものの完全性と公正さを維持する。**

| 原則 | 実際に守ること | CISSPの判断 |
|---|---|---|
| 調査の独立性・倫理的な壁（Ethical Wall） | 調査対象と利害関係のある部署・人物から必要に応じて情報と担当者を隔離 | 部署・役職が上だからといって無条件に調査情報を開示しない |
| 秘密保持 | Need-to-Know、機密保持義務、法的要件、社内手順に従う | 上司・役員でも正当な権限や必要性がなければ共有しない |
| 証拠保護 | 証拠、現場、関連資産の状態を保護・記録 | 先走って原本を操作しない |
| 個人の権利 | プライバシー、適正手続、公正な取り扱い、労働上の権利等を尊重 | セキュリティ目的でも無制限な監視・私物調査は許されない |
| 正式な連絡経路 | 対外連絡は法務・広報・インシデント対応窓口などを通す | 調査担当者が独断で公表しない |

**例：** 社内の不正調査で、疑義のある従業員の上司が「証拠を全部見せて」と要求しても、調査チームは権限・必要性・法的義務を確認したうえで対応する。

## 7.1.2 証拠の対象とアーティファクト

- **証拠になり得るもの**：アクセス・認証ログ、ネットワーク通信、メール、ファイル、端末、侵害が疑われるシステム、現場写真、関係者の証言など。
- **Artifact（アーティファクト）**：調査で意味を持つ物体・記録・デジタル痕跡。PC・携帯電話・USBメモリといった機器だけでなく、ログ、マルウェア検体、レジストリ、メモリダンプ等も含む広い概念。
- **関係があるデータなら何でも無制限に取得できるわけではない。**調査権限・範囲・プライバシー・法令を確認する。

## 7.1.3 証拠の取り扱い：教材の4項目

| 項目 | やること | 具体例／注意点 |
|---|---|---|
| ① 証拠管理人の任命 | 保管、受渡し、アクセス許可を管理する責任者を決める | 証拠保管庫へのアクセスを限定 |
| ② Chain of Custody の維持 | 証拠の保管・移動・取扱いを一貫して記録する | 取得日時、担当者、識別番号、移管先、理由、封印状態 |
| ③ バックアップの使用 | 証拠喪失に備えるとともに、必要な保全用複製を確保する | バックアップと解析用フォレンジックイメージは目的が異なる |
| ④ 原本のコピーを作成 | 原本を保護して複製で分析する | 書込み防止措置を使い、取得前後・必要な時点でハッシュを検証 |

### Chain of Custody と Chain of Evidence

- **Chain of Custody（証拠保管の連鎖）**：取得から提示までの保有・管理・移動の履歴を追跡できるようにするもの。**「誰が扱ったか」**を問われたらこちら。
- **Chain of Evidence（証拠の連鎖）**：文脈によって証拠の一連の取扱いを広く指し、Custodyとほぼ同じ意味で使われる場合もある。資料によっては事実関係と証拠のつながりを説明する意味もある。**名称だけで別個の公式手続きと断定しない。**
- **ハッシュ値（SHA-256等）**：主にデータの同一性・完全性を検証する技術。**誰が扱ったかの履歴をハッシュだけで立証できるわけではない。**
- ハッシュの一致だけで証拠が「合法的に取得された」「その内容が真実である」ことまで確定しない。

> **試験の引っかけ**：デジタル証拠の内容が正しくても、取扱履歴が不明確なら信頼性が損なわれる。逆に、Custodyが完璧でも分析結論に誤りがある可能性は残る。

## 7.1.4 報告および文書化の原則

読み上げでは「許容性・正確性・（3語目は音声が不鮮明）・客観性」の4つ。**3語目は教材原文の照合が必要**なため、ここでは報告品質として必要な「網羅性／理解可能性」を明示しておく。

| 観点 | 意味 | 問題になる例 |
|---|---|---|
| 許容性（Admissibility） | 法令・法廷の証拠採用要件等に適合 | 権限なしの証拠収集 |
| 正確性（Accuracy） | 日時・操作・分析結果などに誤りがない | ログの時刻を誤って解釈 |
| 網羅性・理解可能性（Completeness / Comprehensibility） | 重要事実を省略せず、第三者に説明できる | 不都合なログだけ除外／専門用語だらけで伝わらない |
| 客観性（Objectivity） | 仮説と観測事実を区別して偏りなく記述 | 「怪しいから犯人だ」と断定 |

**調査報告書に記載する項目の例：** 調査目的・許可と範囲、時系列、証拠一覧、収集方法、使用ツール、Chain of Custody、検証結果、事実と推定の区別、限界、結論、推奨事項。

## 7.1.5 調査手法：4つの例

| 手法 | 意味 | 具体例 | 注意点 |
|---|---|---|---|
| **自動キャプチャ** | ツールが継続的・自動的に収集 | SIEMへのログ転送、EDRの端末テレメトリ、パケット収集 | 時刻同期、保存期間、収集漏れ、改ざん防止 |
| **インタビュー** | 人から状況・事実を確認 | 管理者・目撃者・対象従業員に聴取 | 記録、可能なら複数名で実施、適法性、対象者の権利、訓練済み担当者 |
| **手動キャプチャ** | 担当者が必要な証拠を取得 | ディスクイメージ、メモリダンプ、端末写真 | 収集操作で状態が変わり得ることを理解し操作記録を残す |
| **外部への依頼** | 専門組織に調査を委託 | フォレンジック企業への高度な解析依頼 | 調査権限・秘密保持・証拠受渡し・責任分界を定義 |

**インタビューの4つの注意事項**：①可能な限り記録 ②複数人で実施 ③相手の法的・人格的権利を尊重 ④訓練されたインタビュアーが担当。録音の可否は法令・社内規程に従う。

## 7.1.6 デジタルフォレンジックの定義と3原則

**Digital Forensics**＝デジタルの痕跡を証拠として適切に特定・取得・保護・解析・報告し、何が起きたかを検証可能な形で説明する活動。

**基本プロセス**：特定 → 収集・保全 → 検査・分析 → 報告（細部の段階名はフレームワークで異なる）。

| 教材の原則 | 実務での意味 | 具体例 |
|---|---|---|
| **すべてを文書化** | 取得条件、操作、担当者、結果、例外を残す | 解析ツールの版、コマンド、取得時刻を記録 |
| **記録されない／意図しない変更を避ける** | 原本を可能な限り変更しない。避けられない変更は記録 | 書込み防止、フォレンジックイメージ。メモリ収集操作は状態を変え得る |
| **証拠を維持する** | 完全性、機密性、保管履歴、アクセス権限を管理 | ハッシュ検証・保管庫・Chain of Custody |

- **フォレンジックとインシデント対応の違い**：前者は**事実解明と証拠の信頼性**が中心、後者は**検知・封じ込め・根絶・復旧・改善**を含む。現場では並行して進む。
- **揮発性情報**：メモリなど電源断で失われる情報がある。収集順序は状況・安全性・業務影響・法的要件で判断する。
- 根拠：NIST SP 800-86 *Guide to Integrating Forensic Techniques into Incident Response*（参考文献参照）。

### 7.1 試験問題のキーワード → 判断

| 問題文 | 考えるもの |
|---|---|
| 調査対象者の上司から情報提供を要求された | Need-to-Know／倫理的な壁／適切な承認 |
| 証拠を扱った担当者を追跡したい | Chain of Custody |

| 問題文 | 考えるもの |
|---|---|
| 原本を保護しつつ分析したい | フォレンジックイメージ、原本保全 |
| 収集データが改変されていないか確認したい | ハッシュ等による完全性検証 |
| 調査結果を法廷で利用したい | 許容性、適法な収集、Custody、専門家・法務との連携 |
| 観測事実と憶測が混ざっている | 客観性、説明責任、報告品質 |

# 7.2 ロギングおよびモニタリング活動

## 7.2.1 なぜログと監視が必要か

**前提は2つ。**

1. システムが発生させる大量のイベントは、人間がすべてをリアルタイム確認できる量を超える。
2. リアルタイムアラートは、調査する価値のある活動のすべてを検知するわけではない。

したがって、**ログの計画的な収集・保全・正規化・相関分析・報告**と、人による継続的判断の両方が必要。

### Event・Alert・Incident の区別

| 概念 | 定義・例 |
|---|---|
| Event（イベント） | 観測可能な状態変化。ログイン試行、ログアウト、起動、温度・ファン回転変化、入退室バッジ操作 |
| Log（ログ） | イベント等を記録したデータ。すべてのイベントが必ずログ化されるわけではない |
| Alert（アラート） | 条件や分析によって注意が必要と判定された通知。誤検知もある |
| Security Incident（インシデント） | 実際または潜在的にセキュリティを損なう事象など、組織の基準で対応を要するもの |

## 7.2.2 Precursor・Indicator・IoC

| 概念 | 時間のイメージ | 例 | 注意 |
|---|---|---|---|
| **Precursor（前兆）** | 攻撃・インシデントの前 | 攻撃準備と疑われる事前スキャン | 攻撃が必ず発生するとは限らない |
| **Indicator（兆候）** | 発生中または発生後 | IDSアラート、急激な認証失敗、予期しない通信 | その事象だけで侵害確定ではない |
| **IoC（Indicator of Compromise）** | 侵害を示唆する具体的痕跡 | 悪性ファイルハッシュ、不審なC2ドメイン、レジストリ変更 | IP・ドメイン単体では誤判定の可能性 |

**サーバーがキープアライブに応答しない**＝まず可用性異常を示すシグナル。攻撃、障害、ネットワーク遅延など複数の原因があり、直ちに「侵害の証明」ではない。

> **区別**：IoCはIndicatorの一種・関連概念として使われる。**3つが完全に排他的な階層**というわけではない。教材が言う「前兆とインジケーター」は NIST SP 800-61 Rev.2 の伝統的な用語整理と対応する。**現行のSP 800-61 Rev.3は2025年4月発行**で、CSF 2.0に沿ってインシデント対応全体を整理している。

## 7.2.3 構造化されたログ管理：方針から廃棄まで

| 主要項目 | 必要な活動 | 観点／例 |
|---|---|---|
| コンプライアンス・スタンダード | 規制、法、契約、監査の要求を特定 | 保存期間、監査証跡、プライバシー |
| ロギングポリシー | 記録対象、粒度、保持期間、アクセス権、責任者を定義 | リスクに応じて優先度を決める |
| ロギングインフラ | 収集エージェント・転送経路・保管基盤を設計 | 可用性、容量、暗号化、時刻同期 |
| 生成・収集 | OS、ネットワーク、クラウド、アプリから記録 | 重要イベントを取りこぼさない |
| 正規化 | 形式・タイムゾーン・フィールドを整える | 複数ログの時系列照合を可能にする |
| 作成から廃棄までの保護 | 暗号化、アクセス制御、改ざん防止、保管、適切な削除 | 機密性・完全性・可用性を守る |
| レビュー・分析・報告 | ルール・相関・人の確認・監査報告 | 検知精度、対応時間、是正につなぐ |

**「ログは多ければ多いほど良い」は誤り。** 保存コスト、機密情報の過剰収集、分析ノイズ、保持義務などのバランスが必要。

### 対応する規格

| 文書 | 何を扱うか | 間違えやすい点 |
|---|---|---|
| **NIST SP 800-92** | コンピューターセキュリティのログ管理（方針・インフラ・プロセス） | **SP 800-94（IDS/IPS）**とは別。800-92 Rev.1 は改訂ドラフト |
| **ISO/IEC 27001:2013 A.12.4** | イベントログ、保護、管理者ログ、時刻同期 | **旧版の管理策番号** |
| **ISO/IEC 27001:2022 A.8.15** | Logging（ログ取得） | A.12.4.1〜3におおむね対応 |
| **ISO/IEC 27001:2022 A.8.16** | Monitoring activities（監視活動） | 2022年版で明確化された別管理策 |

| 文書 | 何を扱うか | 間違えやすい点 |
|---|---|---|
| **ISO/IEC 27001:2022 A.8.17** | Clock synchronization（時刻同期） | 旧 A.12.4.4 に対応 |

## 7.2.4 IDS / IPS：何を・どこで・どう検知するか

### ① インサイダー／アウトサイダーとゼロトラスト

- インサイダー（内部者）／アウトサイダー（外部者）は脅威分析では有用な分類。
- ただし**アクセスの可否は単純な社内／社外ラベルだけで決めない。**
- 例：人事部員が人事データを閲覧できても、開発部門の機密リポジトリには権限がない可能性がある。
- **ゼロトラスト**ではID、権限、端末状態、対象リソース、状況等を考慮してアクセスを継続的に評価する（NIST SP 800-207の考え方）。

### ② IDS と IPS

| | **IDS（侵入検知）** | **IPS（侵入防御）** |
|---|---|---|
| 主目的 | 不審な活動を**検知・記録・通知** | **検知して遮断などの防御** |
| 代表的配置 | ミラーポート等で監視 | 通信経路上（インライン）等で遮断 |
| 利点 | 本番通信への直接影響が比較的小さい | 被害の未然防止・拡大抑止 |
| 注意 | 検知後の対応が必要 | 誤検知による正当通信の遮断、遅延、障害 |

※製品によってはIDSから外部機器へ遮断要求を送るなど境界が曖昧な場合がある。**試験では基本機能・構成で判断する。**

### ③ ホスト型／ネットワーク型と設置場所

| **型** | **主な対象** | **例** |
|---|---|---|
| HIDS / HIPS | エンドポイントのOS、ファイル変更、プロセスなど | サーバー上で重要ファイル改変を検知・阻止 |
| NIDS / NIPS | ネットワークのパケット・通信フロー | DMZ境界や社内の横展開を検知・遮断 |

- 境界・DMZ：外部との出入りを監視。
- 内部ネットワーク：感染後の横展開（Lateral Movement）や内部脅威に対応。
- エンドポイント：暗号化通信が端末で復号された後の動作を観測できる場合がある。
- **NIDS単体は復号できない暗号化トラフィックの内容を詳細に検査できない。**適切な位置・方式で補完する。

### ④ 悪意ある活動の検知方法

| **方式** | **概要** | **強み** | **限界** |
|---|---|---|---|
| シグネチャベース | 既知の攻撃の特徴と照合 | 既知脅威に強い | 未知攻撃・変種・回避に弱い |

| 方式 | 概要 | 強み | 限界 |
|---|---|---|---|
| 異常・逸脱ベース | 通常の行動ベースラインとの差を評価 | 未知の攻撃兆候を捉え得る | 業務上の変化による誤検知 |
| パターンマッチング | 文字列やフィールド等の規則との照合 | 明確な特徴を検出 | **シグネチャ方式の実装手段として重なる** |
| ヒューリスティック | 経験則・複数の特徴から疑わしさを推定 | 変種・複合的な異常に対応 | 調整・説明・誤検知の課題 |
| ステートフルプロトコル分析 | プロトコルの正当な状態遷移との相違を評価 | 不自然な手順を検出 | プロトコル知識・処理負荷が必要 |

> **重要**：教材の「逸脱／シグネチャ／パターンマッチング／ヒューリスティック」は横並びの語彙だが、必ずしも独立・排他的な4分類ではない。**NIST SP 800-94**は主な検知手法として Signature / Anomaly / Stateful Protocol Analysis を扱う。

⑤ IDS/IPSの運用トレードオフ

| 論点 | 例 | 管理上の判断 |
|---|---|---|
| Maintenance（保守） | ルール更新・チューニング・ソフト更新 | 運用人員と継続的改善 |
| Overhead（性能負荷） | インライン検査による遅延 | 可用性・遅延許容度との兼ね合い |
| False Positive（誤検知） | 正常アクセスを攻撃として遮断 | 業務停止の影響、例外管理 |
| Agility（俊敏性） | 新しいクラウド・IoT環境への追従 | 配置変更、拡張性、運用速度 |

**関連語**：False Negative（偽陰性）＝攻撃を見逃すこと。感度調整で誤検知と見逃しのトレードオフが生じる場合がある。

## 7.2.5 Threat Hunting・MITRE ATT&CK・EDR/XDR

### Threat Hunting（脅威ハンティング）

**アラートが出ていなくても侵害の可能性があると仮定し、仮説を持って能動的に探索する活動。**

**例**：「既存の正規管理ツールを悪用した横展開が起きているのでは？」→ EDR、認証ログ、ネットワーク通信を横断して検証する。

### MITRE ATT&CK

| 概念 | 覚え方 | 例 |
|---|---|---|
| Tactics | **Why：何を達成したいか** | Credential Access（認証情報取得） |
| Techniques | **How：どんな方法か** | OS Credential Dumping |
| Procedures | **具体的にどう実行したか** | 特定のコマンド・ツール・手順による実行 |

**ATT&CKはセキュリティ製品そのものではなく、現実の攻撃者の振る舞いを体系化した知識ベース。** 検知ルール作成・カバレッジ評価・ハンティング仮説に使える。

### EDR / XDR / UEBA の立ち位置

| 技術 | 注目する対象 | 主な仕事 |
|---|---|---|
| EDR | PC・サーバー等のエンドポイント | 端末上の活動の検知・調査・隔離など |
| XDR | 複数領域（エンドポイント、メール、ネットワーク、クラウド等） | 領域横断の検知・調査・対応 |
| UEBA | ユーザー・端末・サービスアカウント等の行動 | ベースラインからの逸脱を分析し、リスク評価 |

※XDRの範囲は製品により異なる。**EDR＝端末中心、XDR＝複数領域を横断**が基本。

## 7.2.6 SIEM（Security Information and Event Management）

**目的**：多様な情報源からセキュリティログ・イベントを集め、**正規化・相関分析・監視・報告**を行う。

### 一般的な入力ソース

ファイアウォール、IDS/IPS、性能監視ツール、ネットワーク機器、ホスト・エンドポイント、マルウェア対策、認証基盤、クラウド監査ログなど。

### 主な7機能

| 機能 | 役割 | 例 |
|---|---|---|
| ① 集約（Aggregation） | 異なる場所からログ収集 | FW＋認証サーバー＋EDR |
| ② 正規化（Normalization） | 形式やフィールドを揃える | タイムゾーン／IP／イベント種別の整形 |
| ③ 相関（Correlation） | 複数イベントの関連を判定 | 連続ログイン失敗＋不審な成功ログイン |
| ④ 安全な保存（Secure Storage） | ログの機密性・完全性・可用性 | 暗号化、改ざん防止、アクセス制御 |
| ⑤ 分析（Analysis） | 脅威や異常の意味を評価 | アカウント乗っ取りの兆候を抽出 |
| ⑥ 報告（Reporting） | 運用・監査・経営層へ共有 | インシデント傾向レポート |
| ⑦ リアルタイム監視 | 条件に応じ通知・追跡 | 高リスクログインを警告 |

**処理の骨格**：集約 → 正規化 → 相関・分析 → 検知・アラート → 調査・報告。**安全な保存**は各段階の基盤。

### 提供・運用形態（教材の4パターン）

| 運用モデル | 「置き場所」と「管理者」の組合せ | 特徴・留意点 |
|---|---|---|
| 自己ホスト・自己管理 | 自社設備を自社運用 | 自由度が高いが設備・運用負荷大 |
| クラウドSIEM・自己管理 | クラウド基盤上で自社運用 | 基盤管理の一部をクラウドへ移せる |
| ハイブリッド自己ホスト | 自社設備＋外部運用支援等を組み合わせる形 | **呼称や具体的責任分界は教材・製品に依存** |

| 運用モデル | 「置き場所」と「管理者」の組合せ | 特徴・留意点 |
|---|---|---|
| SIEM as a Service | SIEM基盤をサービス利用 | 提供内容（基盤のみ／監視運用含む）は契約次第 |

**本質**：*どこに置くか* と *誰が管理するか* を別々に考える。**委託しても自組織のリスク管理責任は消えない。**

## 7.2.7 SOAR（Security Orchestration, Automation and Response）

**目的**：セキュリティツールを連携し、定義済みの対応を自動化・標準化してインシデント対応を速くする。

| 構成要素 | 役割 | 例 |
|---|---|---|
| Orchestration（連携・統合） | ツール・人・プロセスをつなぐ | SIEM → EDR → IAM → チケット管理 |
| Automation（自動化） | 条件によりワークフローを動かす | 悪性IP照会、通知・チケット作成 |
| Response（対応） | 封じ込め・調査・復旧を実施／支援 | 端末隔離、アカウント停止、担当者承認 |

### Playbook / Runbook

- **Playbook**：特定シナリオで**何をどの順番で**進めるかという対応フロー。
- **Runbook**：個々の操作を**具体的にどう実行するか**という手順。
- ただし製品によって名称や粒度が異なり、Playbook自体に具体的な自動処理が含まれることもある。

**例：マルウェア感染が疑われる端末**
SIEMのアラート → SOARがEDR・脅威情報を照会 → リスク判定 → 必要なら人間の承認 → 端末隔離 → チケット起票 → 記録。

**CI/CDとの類似点**：多数のツールとプロセスを統合・自動化すること。**相違点**：CI/CDは開発・テスト・デプロイ、SOARはセキュリティ運用・インシデント対応。

### SIEM / SOAR を即答

| 質問 | 答え |
|---|---|
| 大量のログを集め、異なるイベントを相関分析したい | **SIEM** |
| 検知後に複数ツールを動かし、決まった対応を自動化したい | **SOAR** |
| マルウェア感染端末を検知・隔離する端末中心の機能 | **EDR** |
| メール・クラウド・端末の検知情報を領域横断でまとめたい | **XDR** |
| 「技術的に自動停止できる」なら常に自動で止めるべきか | **No**。可用性・誤遮断・承認権限を評価 |

## 7.2.8 継続的モニタリング（ISCM）

**ISCM＝Information Security Continuous Monitoring。** 対策を入れた時点で終わりにせず、組織のリスク許容度とビジネス環境の変化を踏まえて、セキュリティ状態を継続評価する。

### NIST SP 800-137 の6ステップ

| 順番 | 段階 | やること |
|---|---|---|
| 1 | **Define** | リスク許容度に沿ってISCM戦略を定義 |
| 2 | **Establish** | 指標・頻度・責任者・運用プログラムを確立 |
| 3 | **Implement** | ツール・プロセスを実装しデータを取得 |
| 4 | **Analyze / Report** | 結果を分析・報告（**1段階として扱う**） |
| 5 | **Respond** | 発見された弱点に対応・リスク処理 |
| 6 | **Review / Update** | 戦略・プログラムを見直して改善 |

**暗記順**：**定義 → 確立 → 実装 → 分析・報告 → 対応 → レビュー・更新**。

### 関連標準・フレームワーク

| 名称 | 覚える用途 |
|---|---|
| **NIST SP 800-137** | ISCMプロセスの設計・実施・改善 |
| **ISO/IEC 27004:2016** | ISMSの**Monitoring, Measurement, Analysis and Evaluation**（監視・測定・分析・評価）のガイド |
| **COBIT** | ITのガバナンス・マネジメントを体系化。目標・プロセス・測定・評価を経営とつなぐ |

**補足**：ISO/IEC 27004:2016は2026年10月時点で正式版として掲載され、改訂版が開発中。**ISO 27001はISMS要求事項、ISO 27004は監視・測定・評価のガイダンス**という役割で区別する。

## 7.2.9 Ingress / Egress Monitoring と DLP

### 入口／出口監視

| 比較 | Ingress（入口） | Egress（出口） |
|---|---|---|
| 主眼 | **外から入る通信・脅威** | **外へ出ていく通信・データ** |
| 例 | 外部からのポートスキャン・不正ログイン | 機密ファイルの外部送信、未知の外向き通信 |
| 主な技術 | Firewall、Gateway、認証、IDS/IPS、SIEM、マルウェア対策 | DLP、FW、プロキシ、メール・クラウド監視、IDS/IPS |
| 試験のポイント | 不正アクセスの検知・防御 | **情報持ち出しの監視・防止**、外部C2への通信監視 |

**Ingress/Egressは通信の方向の分類**。FWやIDS/IPSなどは実装・設定次第で両方向に利用できる。

### DLP（Data Loss Prevention）

**対象は3つのデータ状態**：

| 状態 | 英語 | 具体例 | 対策例 |
|---|---|---|---|

| 状態 | 英語 | 具体例 | 対策例 |
|---|---|---|---|
| 保存中 | **Data at Rest** | ファイルサーバー、クラウドストレージ | スキャン・分類・暗号化・権限点検 |
| 移動中 | **Data in Transit / Motion** | メール送信、Webアップロード | 内容検査・送信制御 |
| 使用中 | **Data in Use** | 端末で表示・コピー・USB転送 | エンドポイントDLP・操作制御 |

**情報漏洩対策の流れ**：**発見（Discovery）→ 分類（Classification）→ カテゴリー化・ラベル付け → 監視（Monitoring）→ ポリシー執行（Enforcement）**。必要に応じて**帰属・責任（誰の資産で誰の操作か）**を明確化する。

- **検出技術**：パターン照合、キーワード、正規表現、フィンガープリント、ラベル／機密分類など。
- **具体例**：「社外宛メールに機密ラベル付きファイルを添付」→ 警告・保留・暗号化要求・送信遮断（設定次第）。
- **DLPを有効にする前提**：何が機密データかを発見・分類し、データの所在とオーナーを把握する。

### DLPの役割

| 役割 | 例 |
|---|---|
| コンプライアンス | 個人情報・規制対象情報の持ち出し防止と記録 |
| セキュリティ | 不正・不注意による流出防止 |
| 教育・意識向上 | 警告により安全な取扱いを促す |
| デューデリジェンス | 適切な保護策を実施・説明できる証跡を得る |
| 資産管理 | データの所在・分類・オーナー把握を支援 |

※DLPの機能は製品・配備方法・権限・ポリシーで変わる。**DLP導入だけで機密情報管理が完成するわけではない。**

## 7.2.10 脅威インテリジェンス（Threat Intelligence）

**脅威インテリジェンス**：収集した脅威関連データに、評価・文脈・分析を加え、**防御の意思決定に役立つ知見**に変換する活動・成果物。

### 主な情報源

| 情報源 | 例 | 注意点 |
|---|---|---|
| OSINT（公開情報） | 研究記事、脆弱性情報、公開レポート | 真偽・鮮度・自社との関連を評価 |
| 自社の監視情報 | SIEM、EDR、DNS・認証ログ、脅威ハンティング | 自社への影響を直接判断しやすい |
| セキュリティベンダー | マルウェア解析、IoC・TTPフィード | 品質・鮮度・利用条件 |
| 政府・公的機関 | CISA、CERT等のアドバイザリ | 自社に適用される条件の確認 |
| ISAC等の共有組織 | 業界内の攻撃・対策情報 | 共有ルール・機密保持 |

**ISAC＝Information Sharing and Analysis Center**（情報共有・分析センター）。同業界・重要インフラ等で脅威情報を共有する仕組みの例。

FBI Intelligence Cycle：公式の6段階

| 段階 | 英語 | サイバーセキュリティへの適用例 |
|---|---|---|
| 1 | **Requirements**（要件） | 何の脅威を知る必要があるかを明確化 |
| 2 | **Planning and Direction**（計画・指示） | 情報源、収集方法、優先順位を決める |
| 3 | **Collection**（収集） | OSINT、業界共有情報、内部ログを収集 |
| 4 | **Processing and Exploitation**（処理・活用） | フォーマット整理、翻訳、重複排除、IoC抽出 |
| 5 | **Analysis and Production**（分析・生成） | 情報を評価し、組織への脅威を判断 |
| 6 | **Dissemination**（配布） | SOC、運用担当、経営へ適切な知見を提供 |

**FBIのモデルは6段階。** フィードバック・再評価は継続活動として重要だが、ここに勝手に「公式第7段階」を追加しない。米国の他の情報機関には異なるサイクル分類もあるため、**FBIのモデル名と段階数をセットで覚える。**

**試験の引っかけ**：IoCを集めただけ＝インテリジェンス完成ではない。**評価・文脈付け・伝達によって行動につながる**ことが重要。

## 7.2.11 UEBA（User and Entity Behavior Analytics）

**UEBA**：ユーザー・端末・サービスアカウント等の**通常行動（ベースライン）**と現在の行動を比較し、リスクの高い逸脱を検出する。

教材の「イエローカード／レッドカード」

| 教材の比喩 | 意味 | 例 |
|---|---|---|
| 通常 | 通常の行動に近い | いつもの端末・時間帯からアクセス |
| **イエローカード** | 不審な変化あり、追加確認 | 休日・深夜の珍しいログイン |
| **レッドカード** | 複数の強い異常が重なり優先調査 | 深夜ログイン＋大量データ取得＋未知の送信先 |

**注意**：「黄／赤」は説明の比喩。**UEBAの標準的な色や閾値ではない。**製品によってリスクスコア・しきい値・検知ロジックが異なる。

- **UEBAとシグネチャ**：既知の攻撃文字列との一致に限らず、行動の文脈・通常との差を見る。
- **UEBAとSIEM**：SIEM等のログをUEBAの入力にでき、UEBAの高リスク判定をSIEM/SOARにつなげられる。
- **誤検知**：業務繁忙期や出張等でも異常になり得る。検知だけで処分・アカウント削除を即断しない。

## 7.2.12 モニタリングの限界とSolarWinds（SUNBURST）

| 限界 | 具体的な回避・障害 | 防御・運用の考え方 |
|---|---|---|
| ログそのものの改ざん | 攻撃者がログ削除・時刻変更 | 集中保管、権限制限、完全性検証、時刻同期 |

| 限界 | 具体的な回避・障害 | 防御・運用の考え方 |
|---|---|---|
| 検知閾値の回避 | ゆっくりと少量ずつデータ持ち出し | 長期傾向分析・UEBA・ハンティング |
| ログ転送の保護不足 | 平文・認証なし転送の盗聴／偽装 | 暗号化・認証・安全な収集経路 |
| クラウドの可視性 | CSPが提供するAPI・ログ粒度・権限に依存 | 責任分界・契約・ログ設計を事前確認 |
| マルチクラウドの複雑さ | 異なる形式、時刻、課金、データ移動 | 正規化・相関・費用管理 |
| 人的・運用面の限界 | アラート疲れ、文脈不足、知識不足 | 訓練・手順・担当配置・継続的チューニング |

### SolarWinds侵害と SUNBURST

- 2020年に公になった**ソフトウェアサプライチェーン攻撃**の代表例。正規に信頼されるソフトウェア更新の経路が悪用された。
- SUNBURSTは悪意ある動作の開始を**約12〜14日遅らせる**など、単純な監視に捕捉されにくい仕組みを利用した（Mandiantの技術分析）。
- **「監視機器が設置されている」「署名付きで正規らしい」「大きなアラートがない」＝安全**ではない。
- 教材では米国政府のEINSTEIN等の検知を巡る説明があるが、**個別システムが何を検知・見逃したかは公開情報・適用範囲によって異なる**ため、断定よりも「多層的な検知にも限界がある」という教訓を押さえる。

**最重要結論**：ツール・AI・自動収集は人の判断を代替しきれない。**組織の文脈、リスク、業務影響を理解して継続的に監視・改善する。**

---

# 横断比較：混同しやすい概念

| 比較 | A | B | 正解を分ける軸 |
|---|---|---|---|
| Event vs Incident | 観測された変化 | 対応すべきセキュリティ上の事象 | **イベント全部がインシデントではない** |
| Precursor vs Indicator | 発生前の前兆 | 発生中・後の兆候 | **時間軸** |
| Custody vs Hash | 証拠の管理履歴 | データの同一性検証 | **誰が扱ったか／変わっていないか** |
| IDS vs IPS | 検知・通知 | 防御・遮断 | **本番通信を止めるか** |
| HIDS vs NIDS | 端末・OS・プロセス | ネットワーク通信 | **観測位置** |
| Signature vs Anomaly | 既知の特徴一致 | 通常との差 | **既知／未知、誤検知** |
| SIEM vs SOAR | 集約・相関・分析 | 連携・自動対応 | **見つける／動かす** |
| EDR vs XDR | 端末中心 | 複数領域横断 | **観測・対応の範囲** |

| 比較 | A | B | 正解を分ける軸 |
|---|---|---|---|
| UEBA vs IoC | 行動の異常 | 侵害を示唆する特定の痕跡 | **ベースライン／具体的痕跡** |
| Ingress vs Egress | 入力方向 | 出力方向 | **侵入／持ち出し・外向き通信** |
| DLP vs IDS/IPS | データ保護・持ち出し抑止 | 侵入検知・防御 | **守りたい対象** |
| Threat Intel vs Hunting | 脅威についての分析済み知見 | 仮説に基づき能動探索する活動 | **情報／探索行為** |

# 直前確認：設問のキーワードから答える

| No. | 設問に出てきたら | 最初に思い浮かべること |
|---|---|---|
| 1 | 証拠を誰が扱ったか記録 | **Chain of Custody** |
| 2 | 原本を壊さず分析 | **イメージ取得・コピー分析** |
| 3 | 証拠が変わっていないか | **ハッシュ検証** |
| 4 | 秘密保持と調査の独立性 | **Ethical Wall / Need-to-Know** |
| 5 | 日常の大量イベントを記録 | **Logging** |
| 6 | 不正が始まる前の兆候 | **Precursor** |
| 7 | 悪性ハッシュなどの痕跡 | **IoC** |
| 8 | 不審通信を通知のみ | **IDS** |
| 9 | 不審通信をその場で止める | **IPS** |
| 10 | 既知攻撃を特徴量で検出 | **Signature-Based Detection** |
| 11 | 普段と違う活動を検出 | **Anomaly-Based Detection / UEBA** |
| 12 | アラートがなくても潜伏を探す | **Threat Hunting** |
| 13 | ATT&CKで「なぜ攻撃するか」 | **Tactics** |
| 14 | 多数のログを集約・相関 | **SIEM** |
| 15 | アカウント停止を自動化 | **SOAR**（実行対象はIAM等） |
| 16 | インシデント対応シナリオ | **Playbook** |
| 17 | 具体的な操作手順 | **Runbook** |
| 18 | ログ管理のNIST番号 | **SP 800-92** |
| 19 | IDS/IPSのNIST番号 | **SP 800-94** |
| 20 | 継続的モニタリングのNIST番号 | **SP 800-137** |
| 21 | ISMSの監視・測定・評価 | **ISO/IEC 27004** |

| No. | 設問に出てきたら | 最初に思い浮かべること |
|---|---|---|
| 22 | ISO 27001:2022のLogging | **Annex A 8.15** |
| 23 | ISO 27001:2022のMonitoring Activities | **Annex A 8.16** |
| 24 | ISO 27001:2022のClock Synchronization | **Annex A 8.17** |
| 25 | 社外への機密データ持出し監視 | **Egress / DLP** |
| 26 | 保存中・移動中・使用中の情報保護 | **DLPの適用対象** |
| 27 | 業界で脅威を共有する組織 | **ISAC** |
| 28 | FBIインテリジェンスサイクル | **6段階：要件→計画→収集→処理→分析→配布** |
| 29 | 内部ネットワークの横展開を監視 | **内部NIDS/NIPS、EDRなど** |
| 30 | 「自動遮断できるので即遮断」が常に正解か | **No：リスク・権限・可用性を評価** |

## ミニ確認問題（自習用）

1. 調査員が証拠ファイルのSHA-256を取得した。これでChain of Custodyは完成したか？
2. ゼロトラストでは、社員の接続であれば自動的に社内の全データへアクセスを許可するか？
3. SIEMで大量のイベントが検知された。まず無条件にすべてのアカウントを停止すべきか？
4. IoCを大量に取得するだけで、脅威インテリジェンスを完成したと言えるか？
5. IPSをインラインに配置する場合、検知率のほかに何を考慮すべきか？
6. 「深夜のログイン」1件だけで従業員の不正を断定してよいか？
7. DLPでまず必要になる、機密データの「何が・どこにあるか」を把握する活動は？
8. ISCMは分析・報告を終えた時点で完了するか？

▶ 解答を表示

1. **いいえ。** ハッシュは内容の完全性、Custodyは取扱履歴。
2. **いいえ。** リソースごとに認証・認可・状況を評価。
3. **いいえ。** リスク、誤検知、業務影響、承認権限を評価。
4. **いいえ。** 評価・文脈付け・分析・伝達が必要。
5. **可用性・遅延・誤遮断・障害時の振る舞い。**
6. **いいえ。** 出張・夜間対応など正当な理由があり得る。
7. **データディスカバリと分類。**
8. **いいえ。** 対応 → 見直し・更新 → 継続。

---

# 参考文献・確認先

> これらは公式資料を中心に、番号・定義・段階数の照合に用いたリンク。規格の細かな解釈・法的証拠要件は自組織の法域・契約・教材原文も確認すること。


- NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response
- NIST SP 800-92 — Guide to Computer Security Log Management／Rev.1の改訂状況
- NIST SP 800-94 — Guide to Intrusion Detection and Prevention Systems

- NIST SP 800-137 — ISCMの6ステップ（NIST Glossary）
- NIST SP 800-61 Rev.3 — Incident Response Recommendations（2025年）
- NIST SP 800-207 — Zero Trust Architecture
- ISO — ISO/IEC 27004:2016（改訂ドラフトも参照可）
- FBI — Intelligence Cycle Graphic（6段階）
- MITRE — ATT&CK FAQ：Tactics / Techniques / Procedures
- Mandiant — SUNBURST Additional Technical Details

## 編集上の注記・誤記防止

1. 「NIST SP 890」はログ管理の文脈から **NIST SP 800-92**として整理した。教材で別の番号がある場合は原文確認。
2. 「ISO/IEC 27004、20160」は **ISO/IEC 27004:2016**を指すと解釈。
3. ISO/IEC 27001 Annex A の旧 A.12.4 は **2013年版。2022年版 A.8.15／A.8.16／A.8.17**と混同しない。
4. FBIの6段階は公式のFBIサイクルを採用。一般的な米国情報コミュニティの別分類と混ぜない。
5. 7.1の「報告・文書化」の4原則の**第3語は音声から確定できない**。網羅性・理解可能性という報告品質の観点を併記し、試験直前に教材原本の表記を照合する。
6. SolarWindsの事件は多層防御と監視の限界の**例示**。個別の政府システム・センサーが何を観測していたかを一般化しない。
7. 「3種類の検知方式」などの整理は**NIST固有の分類**。「教材の語彙」やベンダーごとの製品分類と完全一致するとは限らない。

**次の追記開始位置：7.3（次の読み上げ範囲）。**

---

# 7.3｜構成管理を実行する

> **出典区分：会話中の7.3読み上げ内容から再構成（この章の元Markdownは今回の添付に含まれていない）。**
> 以下の具体例・関連規格の補足は試験学習用。

## 1. 構成管理（Configuration Management）と構成項目（CI）

構成管理は、組織のシステムを構成する要素を**特定・記録・統制・検証**し、承認された状態を維持する正式なプロセス。構成項目（**CI：Configuration Item**）は管理対象の部品・要素であり、物理サーバー、VM、OS、アプリケーション、FWルール、ネットワーク設定、クラウドリソース、構成文書などが例。

- **CI識別**：何を管理対象とするか明確化。CIの所有者、バージョン、構成、関係性、重要度を把握。
- **構成制御**：承認を受けない設定変更を防ぎ、変更要求（RFC）と構成情報を紐付ける。
- **構成状態の記録・報告**：現状と承認済み状態の差分を追跡。
- **構成監査・検証**：ベースラインとの乖離（Configuration Drift）や未承認変更を検出。

**例**：本番サーバーのTLS設定やOS版をCMDB・IaC定義に記録し、変更後に承認済み設定との整合性を確認する。**資産管理＝何を持つか／構成管理＝どう組み合わされ、どの状態か。**

## 2. 5種類のベースライン比較

| ベースライン | 定義・対象 | 具体例／覚え方 |
| --- | --- | --- |

| ベースライン | 定義・対象 | 具体例／覚え方 |
|---|---|---|
| **列挙／インベントリ（Enumerated）** | 発見・棚卸しツール等で洗い出した構成要素のリスト | 端末1000台、導入ソフト一覧を自動収集。**何があるか** |
| **構成（Configuration）** | 各CIの版、設定、相互関係を確定した基準 | OS 版、設定値、ミドルウェア構成。**どう設定されているか** |
| **ビルド／配備（Build/Deployment）** | 特定の環境・目的に適合したシステム実装の基準 | 開発・検証・本番用の標準イメージ。**どの形で展開するか** |
| **修正／更新／パッチ（Change/Update/Patch）** | 変更対象のCIに着目した、全体の一部分 | 更新対象パッケージとその適用版。**何を変えるか** |
| **セキュリティ（Security）** | CIごとの最低限受容可能なセキュリティ設定・管理策 | 不要サービス停止、監査ログ有効、暗号化、認証設定。**最低限の安全基準** |

**留意点**：これらは教材で列挙された理解用の分類であり、すべての規格で共通の「公式5区分」とは限らない。正式なベースラインは通常、承認・版管理され、変更統制の基準点となる。

## 3. ベースラインの参考文書・ツール

| 名称 | 関連内容 | 注意点 |
|---|---|---|
| Microsoft **Security Compliance Toolkit** | Windows等の推奨セキュリティベースライン、比較・適用支援 | 対応製品・バージョンを確認 |
| **macOS Security Compliance Project (mSCP)** | NIST等が協力する、macOSセキュリティ設定・文書化のオープンなプロジェクト | OSの版とプロファイルを確認 |
| 米国政府のセキュアホストベースライン関連策 | 政府システムでの標準構成・セキュア設定 | 適用される要求文書を特定 |
| ドイツBSI **IT-Grundschutz** | 組織の情報セキュリティを体系的に保護する基盤的方法 | 個別OS設定集だけではない |
| **NERC CIP** | 北米の電力系重要インフラ向けサイバーセキュリティ要件 | 業界・対象設備への適用条件あり |
| **NIST SP 800-128** | セキュリティ重視の構成管理ガイド | 変更管理・セキュリティベースラインと関連 |

## 4. 構成自動化とプロビジョニング

**Provisioning（プロビジョニング）**は、定義済みの構成ベースラインからシステムを準備・複製し、必要な環境へ展開する活動。例：承認済みイメージでVMを100台展開する、サプライヤーのビルド成果物を受領・検証して自社要件で構成し本番配置する、差分更新パッケージを検証して適用する。

- **IaC（Infrastructure as Code）／構成管理自動化**：宣言された望ましい状態をコード化し、再現性・変更追跡性を高める。
- **ゴールデンイメージ**：事前評価済みの基準イメージ。展開後も更新・監視が必要。

- **構成ドリフト**：実際の状態が承認済み状態からずれること。自動検出・是正が有効。
- **リスク**：誤った基準を自動展開すると**誤設定も大量複製**される。署名・検証、変更承認、段階展開、ロールバックが重要。

## 5. CMBとCCB（変更管理委員会）

- **CMB（Change Management Board）とCCB（Change Control Board）**：教材ではどちらも変更の審査・影響評価・優先順位付け・承認などを担う会議体の名称として登場。組織・フレームワークで役割や名称の定義が変わるため、**文脈に応じてほぼ同じ役割として扱われることがあるが、正式な同義語とは断定しない。**
- 見る点：業務影響、可用性・セキュリティ、依存関係、費用、試験結果、ロールバック、変更後の検証、継続的プロセス改善。
- **委員会が必ずすべての変更を個別審査するわけではない。**標準変更は事前承認を活用し、通常／緊急変更は事前に規定した承認権限・フローを使う。

## 6. 構成・変更・脆弱性・パッチ管理の関係

| 活動 | 主要な問い | 他プロセスとの関係 |
|---|---|---|
| **構成管理** | どのCIが、どの設定・バージョンか | 変更の対象を示す台帳・ベースライン |
| **脆弱性管理** | 何が弱いか、どれほど危険か | 発見・評価・優先順位・追跡、是正を依頼 |
| **パッチ管理** | どの修正をどう安全に適用するか | テスト・バックアップ・展開・検証 |
| **変更管理** | 変更してよいか、影響・承認・実施・検証は適切か | パッチや構成変更を統制 |

**例**：スキャンで脆弱性を発見（脆弱性管理）→対象のOS版を特定（構成管理）→修正を試験（パッチ管理）→RFC評価・承認（変更管理）→適用・確認→CIとベースライン更新。

**CISSP判断**：まず管理対象・基準を把握し、リスクに応じて変更を評価し、権限のある者が承認。効率的な自動化と正式な変更統制を両立させる。

---

# CISSP Domain 7.4 基礎的なセキュリティ運用概念を適用する

> 2026-10-27 音声読み上げ内容をもとに整理。Domain 7.1〜7.2の既存ノートとは別の追補。7.3と統合する際は章順に差し込む。

## 1. 最小権限（Least Privilege）

ユーザー・プロセス・サービス・システムには、**割り当てられた業務を遂行するために必要な最小限の権限**だけを付与する。権限の範囲だけでなく期間も最小限にする。例：バックアップ担当者にバックアップ実行権限は付与するが、人事給与データの閲覧権限は付与しない。適切な実装には定期的な権限棚卸しやJIT（Just-in-Time）特権付与が有効。

## 2. 知る必要性（Need to Know）とNDA

**Need to Know**は「業務上その情報を知る必要のある者だけにアクセスを許す」原則。機密区分・クリアランスなどの資格があるだけでは、個別情報を閲覧してよいとは限らない。**Least Privilege**が操作・システム上の権限を必要最小限にする考え方なのに対し、Need to Knowは**情報へのアクセスの必要性**に焦点を当てる。両者は相補的。

**NDA（Non-Disclosure Agreement、秘密保持契約）**は、受領した機密情報の不適切な開示を契約上禁止する統制。NDAの締結それ自体はアクセス権限の付与を意味せず、Need to Knowやアクセス制御を代替しない。

## 3. 職務分離（Separation of Duties: SoD）と責任

不正・誤操作を防止・発見するため、一人に相反する業務を集中させない。例：支払先の登録者と支払承認者を分ける／開発者と本番リリース承認者を分ける。責任・承認権限・操作権限を明確にし、監査可能な証跡を残す。小規模組織で完全な分離が難しい場合は、上位者による独立レビューや事後監査などの代償的統制を検討する。

## 4. 特権アカウント管理（Privileged Account Management / PAM）

対象：システム管理者、ヘルプデスク、セキュリティアナリスト、運用担当、プロジェクト別管理担当など。特権の濫用・盗用は組織への影響が大きい。

**典型的統制**：

- 通常アカウントと特権アカウントの分離、個人を特定できるアカウント利用、共有特権の抑制。
- より厳格な認証（MFAなど）、アクセス制御、職務・対象・時間の限定。
- JIT/JEA（必要時・必要範囲のみ）、期限付き昇格、自動失効。
- 詳細な操作ログ、セッション記録、監査、定期レビュー。
- 身元・信頼性の確認を職責・リスクに応じて強化。

**アクセス確認の粒度とコスト**：最初に一度認証しただけで無期限・全面信頼するのは危険。一方、すべての微細な操作で重い本人確認を繰り返すと性能・運用負荷が大きい。ゼロトラストは『毎回パスワードを入力させる』ことではなく、リクエストごとに適切なポリシー評価と継続的なリスク判断を行う思想。高リスク操作では追加認証や再評価を行い、セッションやアクセス条件を適切に管理する。

## 5. ジョブローテーション（Job Rotation）

担当業務を定期的に交代する統制。**不正の隠蔽継続を困難にする**、属人化・単一障害点を減らす、知識・技能の共有と相互牽制を促す。ただし、異動に伴うIAM権限の棚卸し・変更・剥奪が必要であり、前任業務の権限を保持したままにしない。人事管理（HRM）とIAMの連携により、Joiner/Mover/Leaver（入社・異動・退職）を反映する。

## 6. 強制休暇（Mandatory Vacation）

従業員を一定期間、業務から離れさせ、その間は他者が業務を代行する内部不正対策。継続的な本人操作が必要な不正や隠蔽が発覚する可能性を高める。職務分離・ジョブローテーションと組み合わせると有効。

## 7. デュアルカストディ（Dual Custody）、二人ルール、ノーローンゾーン

- **Dual Custody（二重管理）**：重要資産・鍵・操作を複数人の共同管理下に置き、一人による単独の持出し・操作を防ぐ。例：重要な暗号鍵へのアクセスに二名の協力を要求。
- **Two-Person Control / Two-Person Rule（二人制御）**：重要操作の実施時に独立した二人の関与・承認を要求。実装は同時操作・二重承認など組織の規程に依存する。
- **No-Lone Zone（単独立入禁止区域）**：指定区域に一人だけで滞在・作業することを禁止。例：重要設備室で常に二名以上が立ち会う。

**区別**：SoDは「業務の役割を分ける」／Dual Custodyは「重要資産・操作を共同管理する」／No-Lone Zoneは「重要区域で単独行動を許さない」。いずれも内部不正・人的ミスの抑止や検出に寄与するが、目的と適用単位が違う。

## 8. サービスレベル契約（Service Level Agreement: SLA）

サービス提供者と利用者との間で、**提供するサービス水準と測定・報告・責任を合意する契約または契約上の取り決め**。可用性（例：月間99.9%）、応答時間、復旧時間、問い合わせ対応、計測方法、除外条件、違反時の対応・サービスクレジットなどを明確化する。セキュリティ関連ではインシデント通知時間、パッチ適用期限、監査ログの提供条件なども重要。SLAがあるだけで安全が保証されるわけではなく、継続監視や提供者管理が必要。

### SLA / SLO / KPI の違い

| 用語 | 中心 | 例 |
|---|---|---|
| SLA | 顧客・提供者間の合意事項 | 稼働率99.9%未満の場合の対応 |
| SLO | 運用品質の目標 | 月間稼働率99.95%を目指す |
| KPI | パフォーマンスを測る指標 | 実測稼働率、平均復旧時間 |

## CISSPでの横断整理

| 統制 | 目的 | 典型的設問のキーワード |
|---|---|---|
| 最小権限 | 過剰な操作権限を防ぐ | 任務に必要な最小限 |
| Need to Know | 機密情報の不必要な閲覧を防ぐ | クリアランスがあっても業務上不要 |
| NDA | 機密情報の開示を契約上制限 | 守秘義務、第三者への開示 |
| SoD | 相反する権限の集中を防ぐ | 作成者と承認者の分離 |
| PAM | 高リスクな特権を厳格に管理 | 特権監査、時間限定昇格 |
| ジョブローテーション | 隠蔽防止・属人化解消 | 定期的な担当交代 |
| 強制休暇 | 継続的な内部不正の発見 | 不在時に代行者が確認 |
| Dual Custody | 単独の重要操作を防止 | 二名の共同管理 |
| No-Lone Zone | 単独の重要区域立入を防ぐ | 常時二名以上の立会い |
| SLA | サービス品質・責任を明確化 | 可用性、復旧、違反時の扱い |

### 確認問題

1. 機密区分上は閲覧可能だが業務上不要なデータへのアクセスを制限する原則は？ → **Need to Know**。
2. 支払申請者と承認者を別人にする統制は？ → **SoD**。
3. 不正の継続的な隠蔽を発見しやすくする人事施策は？ → **強制休暇／ジョブローテーション**。
4. サーバー室内の単独作業を禁止する統制は？ → **No-Lone Zone**。
5. 通常アカウントより短時間・限定範囲で管理者権限を与える手法は？ → **JITを使った特権アクセス管理**。

---

# CISSP Domain 7.5｜リソース保護を適用する

> 学習範囲：メディア管理／媒体保護／保存中・転送中のデータ／NIST SP 800-53・800-88

## 1. 全体像：メディアをライフサイクルで守る

メディア保護の出発点は、**組織がどの媒体を所有・利用しているかを最新のインベントリで把握すること**。資産台帳には所有者、媒体種別、識別子、設置・保管場所、情報分類、状態、利用目的、廃棄状況などを記録する。対象はUSB、HDD/SSD、磁気テープ、バックアップ媒体、光学ディスクだけでなく、紙やマイクロフィルムなどの非デジタル媒体も含む。

**発見・登録 → 分類 → 保管 → 使用・アクセス → 移送 → 再利用／廃棄**を一体として管理する。リスク、情報の機密性、法令・契約上の要件によって管理策の強さを決める。

## 2. メディア管理と保護策

| 段階 | 目的・主な対策 | 具体例／CISSPの着眼点 |
|---|---|---|
| 棚卸し | 資産の全容、保有者、所在地、媒体の機密性を把握 | バックアップテープを資産台帳に登録し保管責任者を明示 |
| 物理保管 | 盗難・紛失・不正な閲覧を防ぐ | 鍵付き保管庫、入退室管理、保管区域の限定 |
| 論理的アクセス | ロール・職務・Need to Knowによってアクセス制御 | バックアップ担当者だけが媒体を取り扱い、アクセスを記録 |
| 環境保護 | 媒体の劣化・破損と可用性低下を予防 | 温度・湿度、液体、埃、煙、磁場などの適切な管理。火災・洪水・地震にも備える |
| 移送・持ち出し | 管理区域外でも機密性・完全性・追跡可能性を維持 | 許可・台帳・受渡記録・耐タンパー包装・暗号化・配送経路管理 |
| 再利用・廃棄 | 残存データの復元や漏洩を防ぐ | 要求される強度のサニタイズ、実施と検証の記録 |

### アカウンタビリティ（説明責任）

誰が、いつ、どの媒体を、どこへ持ち出し、誰に引き渡したかを追跡可能にすること。**許可するだけでなく、実施状況を記録・確認できること**が重要。フォレンジック証拠のChain of Custodyと似るが、媒体管理全般の追跡記録は必ずしも法的証拠の連鎖を意味しない。

## 3. 保存中のデータ・転送中のデータ・使用中のデータ

| 状態 | 意味 | 主な保護策 |
|---|---|---|
| Data at Rest（保存中） | USB、HDD、バックアップなどに格納 | ディスク／ファイル／バックアップ暗号化、鍵管理、物理保護 |
| Data in Transit（転送中） | ネットワーク上や媒体を介して移動 | TLS、VPN、適切な認証、媒体暗号化、安全な配送 |

| 状態 | 意味 | 主な保護策 |
| --- | --- | --- |
| Data in Use（使用中） | メモリやアプリケーション内で処理 | アクセス制御、プロセス隔離、メモリ保護、エンドポイント管理 |

注意：**媒体の物理的な「移送」**とネットワーク上の「転送中データ」**は同一ではない。USBの配送では、媒体内のデータは保存状態のままだが、紛失に備えて暗号化と追跡が必要。

組織の規程や契約・法令によって、未承認USBなどの利用を禁止したり、機微情報を保持するリムーバブル媒体・バックアップを暗号化必須にしたりする。暗号化しても鍵の管理が不十分なら保護にならない。また暗号化は資産台帳・アクセス制御・持ち出し承認・サニタイズの代替にはならない。

## 4. NIST SP 800-53｜MP（Media Protection）ファミリー

SP 800-53は、システムと組織が選択・実装する**セキュリティ／プライバシー管理策のカタログ**。メディア保護のMPファミリーとの対応を押さえる。

| 管理策 | 名称 | 覚え方 |
| --- | --- | --- |
| **MP-2** | Media Access | 誰が媒体へアクセスできるか |
| **MP-3** | Media Marking | 媒体に分類・取扱い表示を付ける |
| **MP-4** | Media Storage | どこに・どう安全に保管するか |
| **MP-5** | Media Transport | 管理区域外へどう運び、どう追跡するか |
| **MP-6** | Media Sanitization | 処分・再利用前に残存データをどう除去するか |
| **MP-7** | Media Use | 媒体の利用をどう制限・管理するか |

関連：**MP-1**はメディア保護の方針・手順。暗号化にはSCファミリー（システム・通信の保護）や鍵管理も関係する。機器の廃棄・再利用では情報分類や資産管理の要件にも留意する。

### 事例で覚える

- 機密テープを施錠庫で保管 → **MP-4**
- 許可者だけがテープを持ち出せる → **MP-2／MP-5**
- 持ち出し記録と受領確認を残す → **MP-5**
- 廃棄前に適切な手法でデータを読めなくする → **MP-6**
- 私物USBの使用を禁止 → **MP-7**

## 5. NIST SP 800-88 Rev.2｜媒体サニタイズ

**SP 800-53が管理策の「何を実施するか」を示す**のに対し、**SP 800-88は「媒体を安全に再利用・廃棄するプログラムや判断方法」を掘り下げる**。

- Media Sanitization：対象データへのアクセスを、想定する労力の下で実行不可能にすること。
- 代表的な概念として **Clear／Purge／Destroy** を理解する。Clearは一定の論理的な回復手段に対応する消去、Purgeはより強い回復耐性を狙う処理、Destroyは媒体自体の破壊。媒体の種類・機密度・再利用の要否に応じて選択する。

- **暗号消去（Cryptographic Erase）**：適切な暗号化・鍵管理を前提に、データ復号に不可欠な鍵を消去する。単に「暗号化してあるから廃棄してよい」という意味ではない。
- 実施した事実だけでなく、方法の妥当性・結果の検証・記録を重視する。
- **Rev.2は2025年9月26日に正式公開**され、2014年のRev.1を置き換えた。Rev.2では個別手法の羅列から、組織的なサニタイズプログラムの構築・運用に重点が移っている。

### 消去、フォーマット、暗号化の違い

通常のファイル削除やクイックフォーマットは、残存データを復元できる場合があり、必ずしもサニタイズにならない。SSD、HDD、クラウド上の論理領域では有効な処理が異なるため、媒体特性とデータ機密度で選択する。

## 6. CISSPで問われる判断

1. **最初にすることは？** → 対象媒体を特定し、分類・所有者・保管場所を把握する。何を守るか不明なまま技術を選ばない。
2. **USBに顧客情報を入れて外部へ持ち出す** → 情報分類に従う許可・暗号化・安全な移送・追跡記録が必要。
3. **暗号化済みバックアップは管理不要？** → 誤り。アクセス制御、鍵管理、環境保護、台帳、サニタイズが必要。
4. **ディスクを再利用するときにファイル削除だけでよい？** → 機微性に応じた承認済みサニタイズと検証が必要。
5. **NISTをどちらから引く？** → 管理策を問う場合 **800-53 MP**、媒体廃棄・消去の具体的な考え方を問う場合 **800-88**。

### ミニ確認問題

**Q1**：バックアップテープの社外搬送時に配送記録を残す行為と最も直接的に対応する管理策は？

▶ 解答

**Q2**：利用終了したSSDを別部署に再配布する前に最優先で検討することは？

▶ 解答

**Q3**：「暗号化されたUSBなら、誰がどこに持ち出してもよい」は正しい？

▶ 解答

## 7. 章の整理の観点

- **ライフサイクル軸**：棚卸し → 保管 → 利用 → 移送 → 再利用／廃棄。
- **守る対象の軸**：媒体そのもの（物理・環境）と、媒体上の情報（アクセス制御・暗号化・消去）。
- **規格の軸**：NIST SP 800-53の**MP-2〜MP-7**と、SP 800-88の**サニタイズ**を対応づける。

## 参考資料


- NIST, *SP 800-53 Rev.5, Security and Privacy Controls for Information Systems and Organizations*, https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
- NIST, *SP 800-88 Rev.2, Guidelines for Media Sanitization* (2025年9月), https://csrc.nist.gov/pubs/sp/800/88/r2/final

- NIST, 2025年9月26日のRev.2公開案内, https://csrc.nist.gov/News/2025/guidelines-for-media-sanitization-rev-2

---

# CISSP Domain 7.6｜インシデント管理を実施する

> 学習ノート：口頭で読み上げた内容の整理＋試験向け補足。2026年10月時点。法令に関する説明は試験用の一般論であり、具体的な報告義務は適用範囲・条件による。

## 0. 全体像

**イベント → 検知 → 分析・インシデント判定 → 封じ込め → 根絶 → 復旧・修復 → 報告 → 教訓と改善**。準備・組織内連携・証拠保全は全体を支える。

- **イベント**：システムやサービスで観測された状態変化。失敗ログインだけで直ちにセキュリティインシデントとは限らない。
- **セキュリティインシデント**：セキュリティポリシー違反、CIAへの悪影響等が発生または切迫する事象。疑いの段階では調査して分類する。イベントとインシデントを同一視しない。
- **目標**：人的安全、被害最小化、重要業務の維持・復旧、証拠保全、法令・契約対応、再発防止。意思決定者の権限を守りつつ対応する。

## 1. インシデント対応の規格・枠組み

### 1.1 NIST SP 800-61

教材の**4段階モデルはNIST SP 800-61 Rev.2（2012）**のもの。

| Rev.2の段階 | 意味 | 代表行動 |
|---|---|---|
| ① Preparation（準備） | 発生前に能力を整える | CSIRT/SOC、ポリシー、連絡網、演習、監視、バックアップ、証拠手順 |
| ② Detection and Analysis（検知と分析） | 発見・真偽判定・影響評価 | SIEM/EDR、ログ相関、IoC検証、重大度分類 |
| ③ Containment, Eradication and Recovery（封じ込め・根絶・復旧） | 拡大を止め、原因を除去して事業再開 | 隔離、マルウェア排除、認証情報変更、安全な復元 |
| ④ Post-Incident Activity（事後活動） | 学びを次の対応へ反映 | 報告、教訓、改善策と期限設定、演習更新 |

**最新版の注意：** 2025年4月公開の**SP 800-61 Rev.3**がRev.2を置き換え、NIST CSF 2.0の6機能（Govern, Identify, Protect, Detect, Respond, Recover）とリスク管理の統合を重視する。教材の旧4段階モデルと最新版の位置づけを混同しない。

出典：https://csrc.nist.gov/pubs/sp/800/61/r3/final

### 1.2 ISO/IEC 27035

教材の典型的な**5段階**：①計画と準備 ②検知と報告 ③評価と判定 ④対応 ⑤教訓（Lessons Learned）。

| 比較軸 | NIST 800-61 Rev.2 | ISO/IEC 27035（教材でのモデル） |
|---|---|---|
| モデル | 4段階 | 5段階 |
| 発見直後 | 検知と分析をまとめる | 検知・報告と評価・判定を分ける |
| 技術的な対処 | 封じ込め・根絶・復旧を明記 | 対応として包含 |
| 終了後 | 事後活動 | 教訓・改善 |
| 本質 | 組織的なインシデント対応サイクル | 同左（粒度・用語の違い） |

※ISO規格には版と分冊があり、詳細な構成は発行年により異なる。試験では設問で指定された版・段階数を優先する。

### 1.3 コンプライアンス・報告義務

| 枠組み | 対象・観点 | 試験上の注意 |
|---|---|---|
| GDPR | EUの**個人データ**侵害（PIIに限定しない） | 管理者は原則、監督機関への通知が必要な場合、侵害を認識してから**可能なら72時間以内**。自然人の権利・自由へのリスクが生じそうにない場合は監督機関への通知が不要。本人への通知は高リスク等の別条件。 |
| HIPAA Breach Notification Rule | 米国の保護対象医療情報（unsecured PHI） | 本人・HHS等への通知。一般に不合理な遅延なく、遅くとも60暦日以内など、相手・事案・規模で要件が異なる。 |
| カナダ PIPEDA | 個人情報侵害 | 実質的損害の重大なリスク（RROSH）等、通知判定が重要。 |
| PCI DSS | カード会員データ環境 | インシデント対応計画・役割・テスト等。報告先や期限はブランド・契約・法規も関係。 |
| COBIT | ITガバナンス・管理 | 責任、管理目標、インシデント対応の組織的統制を考える。 |
| SOC 2 Trust Services Criteria | 監査・保証 | セキュリティに関する対応統制の設計と運用証拠。 |
| EU NIS/NIS2 | ネットワーク・情報システムのセキュリティ | 教材の2016年NIS指令と、その後のNIS2枠組みを混同しない。具体的な適用と報告期限を確認。 |

**原則**：法令順守を「すべての漏洩は72時間以内に報告」などと一般化しない。法務・DPO・契約担当と連携し、適用法、起算点、通知先、証拠、記録を確認する。

## 2. 組織・SOC・エスカレーション

- SOCは監視・分析・優先順位づけ・連絡・対応支援を担う。SOCを独立部門に置くことは必須ではなく、運用・ネットワーク部門等との分担も可能。
- 経営判断を要する**大規模な停止、全社切断、代替サイト稼働**などを、SOCが無条件で独断するべきではない。事前に定めた承認者と代行順位へエスカレーションする。
- ただし**事前承認された手順**に基づく緊急隔離等は、被害拡大防止のため迅速に実施できる設計が必要。「すべて上申待ち」も不適切。
- 重大度、エスカレーション基準、連絡先・代行者、権限、初動SLA、対外窓口、証拠保全方法を事前に定義する。
- 技術的復旧だけでなく、法的対応可能性（証拠の証明力）を保護する。証拠保全より前に無計画な再起動・初期化・ログ削除をすると調査に悪影響がある。

# 3. デジタルフォレンジック

## 3.1 NIST SP 800-86：フォレンジックの4段階

| 段階 | 主な内容 | 例 |
|---|---|---|
| 収集 Collection | 証拠源特定、優先順位づけ、取得と保全 | メモリ・ディスクイメージ、ログ、ネットワーク記録、ハッシュ |
| 検査 Examination | 大量の収集データから関係情報を抽出・整理 | ファイル復元、タイムライン化、ログのフィルタリング |
| 分析 Analysis | 証拠間の関連と意味を評価、仮説を検証 | 侵入経路、時系列、影響範囲、攻撃者の行動を推定 |
| 報告 Reporting | 方法・結果・制約・根拠・推奨対応を伝える | 調査報告書、証跡リスト、再発防止提言 |

**検査と分析の違い**：「何が見つかったか」を抽出するのが検査、「何を意味するか」を判断するのが分析。

証拠の取扱いでは、Chain of Custody（いつ・誰が・何を・どう管理）、原本保護、フォレンジックコピー、ハッシュでの整合性確認、時刻・タイムゾーン、機密性、アクセス権、司法管轄を記録。迅速な封じ込めと証拠保全のトレードオフに注意する。

出典：https://csrc.nist.gov/pubs/sp/800/86/final

## 3.2 ISO/IEC規格の役割

| 規格 | 主な論点 | 一言で覚える |
|---|---|---|
| 27037 | デジタル証拠の識別・収集・取得・保全 | **集めて守る** |
| 27041 | 調査方法の適切性・十分性の保証 | **方法が妥当か** |
| 27042 | デジタル証拠の分析・解釈 | **意味を読み解く** |
| 27043 | インシデント調査の原則・プロセス | **調査全体を設計** |
| 27050（シリーズ） | 電子的証拠開示（eDiscovery） | **法的開示に備える** |

規格の正式名称・最新版は別途確認すること。重要なのは**証拠収集／調査手法／分析／調査プロセス／電子的証拠開示**の役割分担。

### 3.3 フォレンジック体制の4条件

1. 組織の支援・権限・予算・人員を備える正式なプログラムを整備。
2. インシデント発生前に責任者を指定し、道具と手順の訓練を行う。
3. 該当する法域の法令、プライバシー、雇用上の権利などを守る。
4. 平時からログ、時刻同期、保持期間、証拠保全手順などを設計する。

## 4. インシデントレスポンス活動

### 4.1 準備 Preparation

- 役割・意思決定権限・承認経路（RACI等）、CSIRT/SOCと連絡網、広報・法務・人事・経営との協力。
- Playbook/Runbook、重大度分類、判断基準、保全手順、訓練、予備機・復元可能なバックアップ。
- 外部事業者やクラウドの連絡方法、契約上の報告義務、エスカレーション、測定指標（MTTD/MTTRなど）。
- 技術対応を急ぐほど証拠破壊の危険があり、隔離・保全・復旧の優先順位を平時に想定しておく。

### 4.2 検知 Detection

教材の兆候例：

- バッファオーバーフロー、SQLインジェクション等の不審入力。
- AV/EDRによるマルウェア疑い、異常なファイル名。
- ポリシー違反・更新不足の端末や未管理端末の接続。
- 予期せぬ再起動や構成ベースラインの変更。
- 複数回のログイン失敗、見知らぬIPからの認証試行。
- 不審メール・バウンス増加、トラフィック・負荷の異常。

**いずれも兆候であり、単独で侵害確定ではない。**キルチェーンやMITRE ATT&CKで攻撃の進行と照合する。

### 4.3 分析 Analysis

- 何が起きたか、どの資産が対象か、いつからか、被害範囲・機密性/完全性/可用性への影響、攻撃継続中かを分析。
- ログの相関（SIEM）、DNS情報、端末・IP・MAC、資産台帳、時刻同期、構成管理、脅威インテリジェンスが重要。
- 時間をかけて検知したのではなく、**検知済みイベントを分析せずにインシデント化が遅れる**場合もある。
- 誤検知・見逃しや証拠の不確実性を明示し、段階的に判断更新。

### 4.4 対応：封じ込め Containment

**目的：被害拡大を止める（攻撃の足場は残っている可能性がある）。**

| 例 | 狙い | 留意点 |
|---|---|---|
| 感染端末を隔離（EDR/NAC、VLAN、物理切断） | 横展開阻止 | 証拠採取、代替業務、影響範囲 |
| 特定IP・ドメイン・ポート・通信を遮断 | C2や流出経路の阻止 | 正常通信の誤遮断 |

| 例 | 狙い | 留意点 |
|---|---|---|
| VPN・リモートアクセスや無線の一部を停止 | 外部からの再侵入阻止 | 重要業務、緊急時の復旧経路 |
| 外部パートナー接続を一時制限 | 信頼境界で隔離 | 契約・供給網への影響 |
| 侵害アカウント停止／認証情報失効 | 認証を介した拡大阻止 | 正規ユーザーの業務継続 |
| ネットワーク全体／ISP接続の切断 | 最終手段の大規模隔離 | **可用性への甚大な影響。権限と判断が重要** |
| DNS/DHCP等重要インフラの停止 | 必要な場面で特定経路を封じる | 全面停止は業務障害や調査妨害を招くことがあり慎重に判断 |

**CISSPの判断基準**：必要最小限で効果的な隔離を優先し、可用性・人命安全・証拠保全・権限を比較。まず全社ネットワークを切断するとは限らない。

### 4.5 根絶 Eradication

**目的：侵害原因と残存する攻撃手段を除去。** マルウェア、バックドア、悪性アカウント・資格情報、永続化機構を排除し、悪用された脆弱性を是正。必要ならクリーンイメージから再構築。未発見端末に残存していないか確認する。

### 4.6 復旧 Recovery と修復 Remediation

| 用語 | 意味 | 具体例 |
|---|---|---|
| 復旧 Recovery | 安全な状態でサービス・データ・業務を再開 | クリーンバックアップから復元、検証、運用再開宣言、監視強化 |
| 修復 Remediation | 弱点・設定・仕組みを是正し再発可能性を低減 | 脆弱性パッチ、設定変更、MFA強化、不要な接続廃止 |

修復は根絶や復旧と**時間的に重なり得る。**復旧前に必要な修復もある。復旧完了の宣言は業務オーナーと合意した検証基準に基づく。

**例：ランサムウェア** 端末隔離（封じ込め）→悪性ファイルと永続化・侵害資格情報を除去（根絶）→バックアップから再構築し業務再開（復旧）→認証強化・パッチ・ネットワーク分離を改善（修復）。

### 4.7 報告 Reporting

- ユーザー、業務オーナー、関係部署、経営層に復旧完了・残余リスク・制限事項を共有。
- 対外報告（監督機関、顧客、保険会社、捜査機関など）は法令・契約・権限に従う。
- 形式的な「復旧しました」だけではなく、**何が再開され、何が未解決か**を示す。正確性・客観性・証跡を重視。

### 4.8 レビューと改善（Lessons Learned）

- 時系列、検知から判断までの時間、判断の妥当性、証拠取扱い、コミュニケーションを振り返る。
- 責任追及だけに終始せず、根本原因と統制不備を修正。
- 改善の担当者・期限・効果確認方法を明確化し、Playbook、教育、構成基準や監視ルールへ反映する。

## 5. 根本原因分析（Root Cause Analysis, RCA）の5手法

| 手法 | 切り口 | 例・用途 | 注意点 |
|---|---|---|---|
| パレート分析 | **頻度・影響の大きい原因から優先** | 障害の大部分を占める設定ミス・運用漏れを見極める | 80:20は経験則であり必ず成立しない |
| 5 Whys（なぜなぜ分析） | **なぜ？を段階的に深掘り** | パッチ未適用→管理台帳にない→発見プロセス欠落 | 5回固定でも単一原因限定でもない |
| フィッシュボーン（石川ダイアグラム） | **原因を分類・可視化** | 人・手順・技術・環境等から漏れなく候補抽出 | 列挙は原因の実証ではない |
| FMEA（故障モード影響解析） | **部品・工程の故障モードから影響へ**（ボトムアップ） | 認証基盤の故障が業務へ与える影響を事前評価 | 主に予防的リスク評価にも使う |
| FTA（フォールトツリー解析） | **望ましくない結果から原因を逆算**（トップダウン） | 「情報流出」に至る条件をAND/ORで展開 | 論理関係の妥当性を確認 |

CISSP頻出対比：**FMEA＝原因候補（故障モード）→結果／FTA＝結果（トップイベント）→原因**。RCAで確定した原因と、仮説・兆候を混同しない。

## 6. 重要用語の対比（直前暗記用）

| 比較 | 覚え方 |
|---|---|
| イベント vs インシデント | **変化の観測** vs **セキュリティに関係する事象として対応が必要** |
| 検知 vs 分析 | **兆候を見つける** vs **関連づけて意味・重大度を判断** |
| 封じ込め vs 根絶 | **拡大を止める** vs **原因・攻撃手段を取り除く** |
| 復旧 vs 修復 | **安全に業務再開** vs **弱点を是正し再発防止** |
| SOC vs 経営・業務責任者 | **技術分析・エスカレーション** vs **権限に応じた重大業務判断** |
| NIST 800-61 Rev.2 vs Rev.3 | **4段階の典型的IR** vs **CSF 2.0と統合したリスク管理視点** |
| NIST 800-86 vs ISO 27037等 | **フォレンジック統合と4段階** vs **証拠取扱い・妥当性・分析等の国際規格** |

## 7. CISSP的な判断の優先順位

1. 生命・安全と重要業務を考慮する。
2. 事前定義された手順と権限に基づき、重大な決定を適切にエスカレーションする。
3. 被害拡大を抑えつつ、調査と訴訟のための証拠保全を忘れない。
4. 一律の全停止ではなく、リスクに見合った封じ込めを選ぶ。
5. 復旧後も報告・RCA・管理策改善まで実施して初めてサイクルが閉じる。

## 8. セルフチェック

1. 攻撃の疑いがある1台のPCを発見した際、ネットワーク全体切断の前に検討すべきことは？
2. なぜログの時刻同期がインシデント判定に役立つ？
3. マルウェアを削除しただけで復旧完了といえる？ なぜ？
4. FMEAとFTAはどちらから原因をたどる？

5. SOCが重大な業務停止を独断で決めないために、準備段階で何を定義する？
6. NIST 800-61の4段階モデルはRev.2とRev.3のどちら？

確認問題の要点

1. 対象を局所隔離できるか、影響・証拠保全・事前承認の条件を評価。
2. 異なる機器・ログの出来事を同一時間軸で相関できる。
3. 残存するアクセス経路や攻撃手段、弱点を排除・検証して安全に再開する必要がある。
4. FMEAは故障モード→影響、FTAは望ましくない結果→原因。
5. 重大度、承認者と代行者、エスカレーション、緊急時の事前承認済み対応。
6. Rev.2。Rev.3は2025年に公開されCSF 2.0と連携。

---

## 参考文献


- NIST SP 800-61 Rev.3 (2025): https://csrc.nist.gov/pubs/sp/800/61/r3/final
- NIST SP 800-86 (2006): https://csrc.nist.gov/pubs/sp/800/86/final
- ISO/IEC 27037: https://www.iso.org/standard/44381.html
- ISO/IEC 27042: https://www.iso.org/standard/44406.html
- 欧州GDPR 第33条・第34条、米国HIPAA Breach Notification Rule、カナダPIPEDA：各法令の適用条件は要確認。


---

# CISSP Domain 7.7｜検知及び防止策を運用・維持する

> 学習ノート：音声で読み上げた教材の論点を、定義・具体例・技術の違い・CISSP判断基準で再構成。2026-10-27時点。製品・法規の仕様は適用環境と最新版を確認。

## 1. 全体像：Prevent / Detect / Respond

- **予防（Preventive）**：不正な通信、実行、アクセスを未然に阻止（FW、IPS、許可リスト、パッチ適用）。
- **検知（Detective）**：不審な活動を発見・通知（IDS、ログ監視、ハニーポット、EDR）。
- **対応（Responsive/Corrective）**：検知後の遮断・隔離・復旧（SOAR、EDRの端末隔離、インシデント対応）。
- **抑止（Deterrent）**：攻撃意欲を減らす。検知と抑止は異なる。
- 一つの製品が複数機能を持つ。**「機器名だけ」ではなく、具体的に何をする制御か**で分類する。

## 2. ファイアウォール・IDS・IPS・NGFW

| 技術 | 主な目的 | 代表的な動作 | 留意点 |
|---|---|---|---|
| ファイアウォール（FW） | 通信ポリシーの強制 | 送信元・宛先・ポート・状態などで許可/拒否 | 許可された通信の内部の不正を必ずしも検知しない |
| IDS | 侵入の検知・通知 | 不審な通信や端末活動についてアラート | 通常は通信を直接ブロックしない |
| IPS | 侵入の防止 | シグネチャ/異常検知に基づき遮断 | 誤検知が可用性に影響し得る |

| 技術 | 主な目的 | 代表的な動作 | 留意点 |
|---|---|---|---|
| NGFW | FWに高度な識別・検査を統合 | アプリケーション識別、ユーザー識別、IPS等 | 暗号化通信の可視性、性能・運用負荷、誤遮断に注意 |

- **NIDS/NIPS**：ネットワークのトラフィックを観測・防御。**HIDS/HIPS**：端末やサーバー内部の事象を観測・防御。
- NGFWに**AI/MLによる分析や自動ポリシー変更**を備えた製品はあるが、NGFWに必須の共通機能ではない。自動変更は検証・承認・ロールバックを考える。
- 防御の基本原則：最小権限、既定拒否、必要な通信のみ許可。可用性とのバランスを経営・業務リスクで判断。

**例**：外部からWebサーバーの443/TCPを許可するFWは、HTTPS通信を通す。一方、その通信内容に攻撃パターンがあればIPSやWAFが検知・遮断できる場合がある。WAFはHTTP(S)アプリケーション層を中心に守り、一般的なFWとは役割が異なる。

## 3. 許可リスト（Allowlist）とブロックリスト（Blocklist）

| 観点 | 許可リスト | ブロックリスト |
|---|---|---|
| 原則 | **許されたものだけ実行・アクセス可** | **禁止対象以外は利用できる** |
| 基本設計 | Default Deny（既定拒否） | Default Allowを採用する場合が多い |
| 強み | 未知の無許可ソフトにも比較的強い | 新規アプリへの対応が柔軟 |
| 課題 | 事前承認・更新・依存関係管理に手間 | 未知の悪質ソフトを見逃し得る |
| 例 | 署名済み業務アプリだけ実行 | 既知のマルウェアのハッシュを拒否 |

- 対象は実行ファイル、スクリプト、ライブラリ、コマンド、ドメイン、IPなどに広がる。
- 許可の判定材料：ファイルハッシュ、電子署名、発行者、ファイルパス等。パスだけでは成り済ましに弱いことがある。
- テキスト中の **Allowed / Blocked** は一般的な「許可された状態／拒否された状態」と捉える。実行制御と通信制御で実装は異なる。
- **NIST SP 800-167『Guide to Application Whitelisting』**：アプリケーション許可リスト（Application Control）の計画・導入・運用を扱う（2015年）。https://csrc.nist.gov/pubs/sp/800/167/final

## 4. サードパーティ提供のセキュリティサービス

| 委託分野 | 業務例 | 自社で確認すべきこと |
|---|---|---|
| 脅威インテリジェンス | IoC・攻撃者動向の収集・分析 | 情報源、鮮度、誤検知、共有制限 |
| ネットワークモニタリング | 24時間の通信監視・アラート | 監視範囲、検知能力、通知遅延 |
| 物理セキュリティ | 入退室管理・監視カメラ運用 | 施設アクセス、記録保管、緊急対応 |
| ネットワーク管理 | FW設定、構成管理、機器運用 | 変更承認、権限分離、ログ、復旧 |
| 監査 | 独立した管理策評価・報告 | 独立性、監査範囲、是正措置の追跡 |

**MSSP**（Managed Security Service Provider）は広い管理型セキュリティサービス。**MDR**（Managed Detection and Response）は検知・調査・対応支援に重点。SOCアウトソースなど、契約内容で役割は変化。

### 4.1 委託先デューデリジェンス

| 確認事項 | 確認ポイント・具体例 |
|---|---|
| ガバナンスのレビュー | 組織体制、責任者、アクセス権管理、再委託先管理、法令遵守 |
| SLA | 稼働率、検知・通知・初動時間、障害復旧、エスカレーション、未達時対応 |
| NDA | 秘密情報の定義、利用目的、共有先、返却・削除、存続条項 |
| 保険・保証 | サイバー保険、補償範囲、免責、責任上限を契約と整合 |
| 監査・テスト | SOC報告書などの保証報告、脆弱性評価、ペンテスト、監査権限 |
| 強固な契約条項 | 通知義務、監査権、データ所在地、再委託、退出・移行、証拠保全、BCP |
| 規制当局の承認 | 該当業種・法域で事前承認や届出が必要か確認。**常に必要とは限らない** |

**CISSPの核心：業務を委託できても、リスクへの説明責任（Accountability）は委託できない。** 契約前の審査だけでなく、契約期間中も定期レビューを行い、終了時にはデータ・権限・ログ・資産を回収する。

**参考**：NIST SP 800-161 Rev.1（サプライチェーンリスク管理）、NIST SP 1326（Due Diligence Assessment Quick-Start Guide、2026年7月最終版）。https://csrc.nist.gov/pubs/sp/1326/final

### 4.2 公共調達の制度例

- **EU**：EU公共調達指令が共通枠組みを設け、加盟国が国内法や要件で具体化する。個別調達・法域への適用確認が必要。
- **カナダ**：Government Contracts Regulations と、Public Services and Procurement Canada が使う **SACC（Standard Acquisition Clauses and Conditions）Manual** 等。
- **米国**：**FAR（Federal Acquisition Regulation）** は連邦調達の基本的なルール。政府機関・契約の種類に応じた補足要件も存在。
- 共通点は、透明性、適切な競争、調達仕様、契約条項、遵守・監査の確保。**法域ごとの適用要件を一律に扱わない**。

## 5. サンドボックス・ハニーポット・ハニーネット

| 技術 | 目的 | 例 | 注意事項 |
|---|---|---|---|
| **サンドボックス** | 不審コードを制限環境で実行・分析 | メール添付ファイルを隔離して挙動解析 | 仮想環境を検知して攻撃を隠すマルウェア、解析環境からの逸脱リスク |
| **ハニーポット** | おとり資産で攻撃を検知・観察 | 偽のSSHサーバーへのログイン試行を観測 | 侵害されても実ネットワークに横展開できないよう分離 |
| **ハニーネット** | 複数のおとりシステムから攻撃行動を観察 | おとりWeb・DB・認証基盤を接続 | 運用・隔離・法的配慮が複雑 |

- **サンドボックス**＝「怪しいものを安全に試す場」。**ハニーポット**＝「攻撃者を引き寄せて観察するおとり」。

- **DMZ**＝外部公開サービスなどを内部ネットワークと分離するセグメント。ハニーポットの配置場所の選択肢だが、DMZへの設置は必須ではない。DMZそのものとハニーネットは同義でない。
- ハニーポットに実データを置かず、収集ログの保全、監視、通信制限、対応手順を準備する。
- ハニーポットに触れた事実は調査すべき強い兆候になり得るが、**その時点で全ての事象が攻撃確定とは限らない**。

## 6. マルウェア対策のサイバー衛生（Cyber Hygiene）

1. **導入前評価**：OS・製品・ライブラリの提供元、更新体制、脆弱性、署名、サプライチェーンリスクを審査。
2. **電子メール**：添付ファイルの検査、危険なリンク・マクロの制限、フィッシング教育、メール認証（SPF/DKIM/DMARC）の利用。
3. **記憶媒体とデータ**：USB等の利用制限・暗号化、個人クラウドと業務データの混在禁止または統制、DLP、ログ。
4. **BYOD・ゲスト端末**：資産・デバイス識別、MDM/UEM、条件付きアクセス、業務データ分離、退職時の権限削除。
5. **外部ネットワーク・クラウド**：利用許可、認証/MFA、共有設定、VPN/ZTNA、信頼境界と監視範囲の明確化。
6. **技術的な標準設定**：アンチマルウェア、ホストFW、最小権限、パッチ管理、実行制御、ログ、バックアップ。
7. **ネットワーク接続時のヘルスチェック**：NAC/ポスチャ評価でOS更新、マルウェア対策の稼働、証明書、暗号化状態を確認。未準拠端末は拒否・隔離・修復ネットワークへ誘導。

「2020 Desk Reference Guide／Alan Watkins」の書誌情報は、この読み上げだけでは正確な文献特定に確証がないため、学習ノートでは断定せず、上記の実務上の対策として整理した。

## 7. アンチウイルス・アンチマルウェアの3アプローチ

| アプローチ | 何を見るか | 具体例 | 得意／不得意 |
|---|---|---|---|
| **既知のシグネチャスキャン** | 既知マルウェア特有のコード・パターン | ウイルス定義との一致 | 既知の脅威に強い／未知・難読化に弱い |
| **アクティビティモニタリング** | 実行中の**振る舞い** | 大量暗号化、特権昇格、怪しい外部通信 | 未知の不正を発見可能／誤検知あり |
| **変更検知** | ファイル・設定などの整合性 | 重要ファイルのハッシュ変更、レジストリ改変 | 不正改変の兆候に強い／正当な更新との区別が必要 |

- 3つは排他的ではない。最新の製品はシグネチャ、振る舞い、機械学習、レピュテーション等を併用する。
- **FIM（File Integrity Monitoring）** は変更検知の代表例。基準値を決め、変更を検出・調査する。変更検知だけで悪性を確定できない。

### 7.1 ツール・検知方式の違い

| 名称 | 機能 | 想定例 |
|---|---|---|
| スキャナー | ファイルやメモリ等を検査 | 定期・オンデマンド・リアルタイム検査 |

| 名称 | 機能 | 想定例 |
|---|---|---|
| ヒューリスティックスキャナー | 未知の脅威を特徴・規則から推測 | 不自然な命令列やマクロ構造を警戒 |
| アクティビティモニター | 実行中の挙動を観察 | 大量のファイル暗号化を検出 |
| 変更検知ツール | ベースラインからの変更を検知 | システムファイルや設定の整合性監視 |
| レピュテーションモニタリング | ファイル・IP・URL・ドメインの過去の評判を参照 | 悪性ドメインへの接続を警告 |
| ゼロデイ／ゼロアワー対策 | 未公開・対策前の脆弱性や新種の攻撃に備える | 振る舞い分析、隔離、実行制御、仮想パッチ |

**注意**：「ゼロデイ」は脆弱性や悪用の時点に関する概念であり、スキャナーの一種類とは限らない。「ゼロアワー」は新種マルウェア発生直後などを強調する表現。ゼロデイを必ず検出できる万能技術はない。

### 7.2 Webレピュテーションスコア

| リスク分類の例 | 意味 | 典型的な運用例 |
|---|---|---|
| 高リスク | 悪性・危険性が高い | 原則ブロック、SOC通知 |
| 疑わしい | 未確認の危険兆候 | 隔離、追加検査、確認 |
| 中程度のリスク | 一定の懸念 | 条件付き許可、監視強化 |
| 低リスク | 懸念が小さい | 通常の監視を付けて許可 |
| 信頼できる | 評判が良いと評価 | ポリシーに基づいて許可 |

- **この5段階は教材の理解用の例。**カテゴリ、点数、閾値、応答動作はベンダーによって違う。
- 評価対象は URL、ドメイン、IP、ダウンロードファイル等。DNSベースの対策、Webプロキシ、SWGなどと連動できる。
- レピュテーションが高いサイトも侵害されることがある。**信頼スコア≠安全の保証。**過信せず多層防御を組み合わせる。

## 8. AI・機械学習（ML）による検知と防御

### 8.1 従来型のルールとの違い

- **ルールベース**：事前定義したしきい値、シグネチャ、KPI・KRI等に基づき通知（例：5分でログイン失敗10回）。
- **ML/AIによる分析**：大量の行動・通信・ログデータからパターンや逸脱を抽出し、ルールに明記していない事象を識別する助けになる（例：時間帯・取得量・アクセス先の組合せによる異常）。
- **KPI**＝成果・運用状況を把握する指標（例：平均検知時間MTTD）。**KRI**＝リスクの高まりを示す指標（例：重大脆弱性の未修正台数）。AI/MLとKPI/KRIは対立概念でなく、併用される。

### 8.2 導入時の判断軸

1. **目的適合性**：守る対象・想定脅威・業務影響に合うか。

2. **検知品質**：真陽性・偽陽性・偽陰性、モデルドリフト、環境変化に伴う再学習。
3. **説明可能性**：なぜ警告したか、調査・監査できるか。
4. **安全な運用**：自動遮断をどこまで許すか。重大な業務停止を伴う操作は承認を設ける。
5. **総コスト**：導入費、データ収集・保存、運用人員、分析負荷、可用性への影響。
6. **データ保護**：学習・推論に使う機密情報、委託先、ログへのアクセス。
7. **攻撃者による利用**：自動化、フィッシング文章生成、脆弱性探索、回避技術等にAI/MLを悪用し得る。

**CISSP的な判断**：最新技術を導入すること自体を目的にせず、**組織のリスクと事業上の必要性に合わせて選択・評価・監督する。**技術は人の判断を補助するが、組織の説明責任は残る。

## 9. 典型的な比較問題・引っかけポイント

| 問われ方 | 押さえる答え |
|---|---|
| 通信を遮断したい | FW/IPS等。IDS単体は主に検知 |
| 既知・未知を問わず、未承認アプリの実行を抑えたい | Allowlist（運用負荷は高い） |
| 不審な添付ファイルを試す | サンドボックス |
| 攻撃者の行動をおとりで観察する | ハニーポット／ハニーネット |
| USB持込端末が更新済みか接続前に確認する | NAC・ポスチャチェック |
| 正常ファイルの改ざんを知りたい | 変更検知・FIM |
| 新種マルウェアの怪しい動作を知りたい | 行動監視・ヒューリスティック分析 |
| 信頼できるWebサイトなら無条件に安全か | いいえ。評判は一指標に過ぎない |
| 外部SOCが監視していれば自社の責任はなくなるか | いいえ。説明責任・リスク統治は組織に残る |
| AIが高リスク判定したら常に自動遮断すべきか | いいえ。誤検知・可用性・権限・影響を評価 |

## 10. 確認問題（自習）

1. 既知の攻撃コードと一致しないランサムウェアによる大量暗号化を最も検知しやすい方法は？ → **行動／アクティビティモニタリング**。
2. 新しい正規アプリの実行がブロックされた。どの方式の典型的な運用課題か？ → **許可リスト**。
3. 複数の偽装ホストを用いて攻撃者の横展開を観察したい。 → **ハニーネット**。
4. リモート委託先が不正行為を起こした場合、組織のリスク説明責任は完全に移るか？ → **移らない**。
5. 重要システムのハッシュ差異が見つかった場合、直ちに攻撃確定か？ → **確定しない**。承認済み変更・更新との照合が必要。
6. AIベースの製品が誤検知で業務停止を起こし得る。何を重視するか？ → **ビジネス影響、閾値調整、人的承認、テスト・ロールバック**。

## 11. 関連する既習内容

- **7.2 ロギング・モニタリング**：IDS/IPS、SIEM、SOAR、UEBA、脅威インテリジェンス。
- **7.3 構成管理**：パッチ・ベースライン・変更管理・構成ドリフト。
- **7.4 基礎的な運用原則**：最小権限、職務分離、SLA、委託の責任。
- **7.5 メディア保護**：USB、暗号化、アクセス制御、媒体のライフサイクル。

- **7.6 インシデント管理**：監視アラートの分析、検知後の封じ込め・根絶・復旧。

## 参考資料

- NIST SP 800-167, *Guide to Application Whitelisting*（公式）：https://csrc.nist.gov/pubs/sp/800/167/final
- NIST SP 1326, *Cybersecurity Supply Chain Risk Management: Due Diligence Assessment Quick-Start Guide*（2026年）：https://csrc.nist.gov/pubs/sp/1326/final
- NIST SP 800-83 Rev. 1, *Guide to Malware Incident Prevention and Handling for Desktops and Laptops*：https://csrc.nist.gov/pubs/sp/800/83/r1/final

---

一言で覚える

**FW・IPSは止める、IDSは見つける。Allowlistは許可したものだけ。Sandboxは試す、Honeypotは誘う。シグネチャは既知、行動監視は振る舞い、FIMは変更。委託しても説明責任は残り、AIはリスクに合わせて運用する。**

---

# 7.8｜パッチ及び脆弱性管理を実装・支援する

> **出典区分：会話中の7.8読み上げから再構成（この章の元Markdownは今回の添付に含まれていない）。** 以下の具体例は理解のための補足。

## 1. 脆弱性管理とパッチ管理の違い

- **脆弱性管理（Vulnerability Management）**：資産・脆弱性の**発見→評価→優先順位→是正追跡→再評価**を継続する活動。スキャン、リスク評価、脅威モデリング等によって弱点を識別する。
- **パッチ管理（Patch Management）**：修正プログラムや更新を**選定・試験・承認・適用・確認・記録**する実行管理。脆弱性への対処の一つであり、全部ではない。
- 脆弱性対処は**パッチ以外**にも、構成変更、機能停止、ネットワーク分離、補完的管理策、システム廃止等がある。

**例**：公開Webサーバーに重大な欠陥が判明→影響と悪用状況を評価→ベンダーパッチを検証・適用。ただしパッチが未提供ならWAFルールやアクセス制限などの一時的緩和策を検討。

## 2. パッチ管理での5つの課題

| 課題 | 具体例・なぜ問題か | 対応の方向 |
|---|---|---|
| **相互運用性** | OS更新が業務アプリ・周辺ソフトと衝突 | 互換性確認・検証環境 |
| **不適切に作成されたパッチ** | パッチ自体に不具合、パフォーマンス低下 | 供給元確認・テスト・段階配備 |
| **ダウンタイム** | 再起動で24時間サービスが停止 | メンテナンス枠・冗長化・業務調整 |
| **仮想化特有の懸念** | VMテンプレート・停止中VM・スナップショット等に未更新資産が残る | 仮想基盤・イメージ・一時VM含めた棚卸し |

| 課題 | 具体例・なぜ問題か | 対応の方向 |
|---|---|---|
| **タイミング** | 早期適用の必要性と十分な検証時間が競合 | リスクと脅威の緊急性による優先順位 |

## 3. パッチ適用の標準的な一連の活動

| 順 | 手順 | 具体的な観点 |
|---|---|---|
| 1 | **通知取得** | ベンダー、第三者アドバイザリ、脆弱性データベース、ニュースを定期監視 |
| 2 | **分析と優先順位** | 自社製品の利用状態、露出、重大度、悪用実績、重要業務、依存関係を評価 |
| 3 | **影響評価** | 可用性、性能、互換性、法令、想定停止時間、戻し方を明確化 |
| 4 | **テスト** | 検証環境で機能・回帰・互換性・安全性を確認 |
| 5 | **バックアップ／復旧準備** | 適用前の必要なバックアップ、復元性とロールバック手順を検証 |
| 6 | **正式な変更承認・適用** | RFC／変更管理と連携、ベンダー指示・自社手順に従い段階導入 |
| 7 | **全対象の適用検証** | バージョン・ログ・スキャン結果を照合し未適用資産を確認 |
| 8 | **利用者フィードバック収集** | 業務影響や予期しない不具合を確認 |
| 9 | **必要ならロールバック** | RFCで規定した失敗条件・戻し方・判断権限に基づく |
| 10 | **記録・資産台帳更新** | 適用日・版・対象CI・例外・残余リスクを記録 |

**留意点**：緊急パッチは手順を**迅速化**しても変更の統制や事後検証を放棄しない。常に「完全なフルバックアップが唯一の正解」ではなく、環境に適した**復元可能な保全策**を選ぶ。運用によっては再起動・ロールバックが難しいこともある。

## 4. CISSP向けの補足：脆弱性評価に用いる情報

- **CVSS**：脆弱性の技術的な深刻度の指標。自社での実際の影響・優先順位を単独では決めない。
- **CVE**：公表済み脆弱性の識別子。リスクのスコアではない。
- **KEV**：実際に悪用された既知の脆弱性のカタログ（CISA）。脅威の緊急性評価の参考。
- **例外承認・補完策**：レガシーシステム等で修正不可なら隔離・アクセス制限・監視等を検討し、残余リスクを適切な責任者が判断。

**一言で覚える**：**脆弱性管理＝弱点を見つけてリスクを管理／パッチ管理＝更新を安全に実行／変更管理＝変更の承認と統制／構成管理＝正しい状態を記録。**

---

# CISSP Domain 7.9｜変更管理プロセスに参加し、理解する

> 学習範囲：読み上げ内容に基づく整理。CISSPの判断軸、関連規格、具体例を補足。

## 1. 変更管理の目的

変更管理（Change Management）は、現在の状態から承認された将来の状態へ、**リスク・業務影響・追跡可能性を管理しながら移行**する組織的な活動。大きく、(1)変更を決定する、(2)変更を実行する、(3)期待した結果を検証する、という3段階で理解する。

**例：** 本番DBサーバーのバージョンアップ。影響範囲と停止時間を評価し、権限者が承認し、計画に沿って実施し、動作確認・記録更新まで行う。

## 2. 混同しやすい概念

| 概念 | 主な役割 | 例 |
|---|---|---|
| 変更管理（Change Management） | 変更の要求から承認、計画、実施、評価までを統括 | 本番DB更新の変更プロセスを管理 |
| 変更コントロール（Change Control） | 変更対象・影響・承認条件・手順を統制し、無断変更を防ぐ | 変更対象CIと実施手順を確認 |
| 構成管理（Configuration Management） | CIとそのバージョン・依存関係・ベースラインを管理 | 更新前後のOSバージョンを記録 |
| 回帰テスト（Regression Testing） | 変更箇所以外の既存機能に意図しない不具合がないか確認 | DB更新後も既存の受注機能が動くか確認 |
| パッチ管理（Patch Management） | パッチを評価・テスト・適用・確認する | セキュリティパッチを段階的に展開 |

**ポイント：** 変更管理は全体プロセス、変更コントロールは無秩序な変更を防ぐ統制。両者の用語は組織やフレームワークによって重複して使われることがある。

## 3. 変更管理プロセスの流れ

1. **RFC（Request for Change：変更要求）作成**：目的、対象CI、変更理由、期待成果、実施候補日時、リスク・影響、依存関係、検証方法、ロールバック案を記載する。
2. **分類・影響評価**：標準／通常／緊急かを判定し、機密性・完全性・可用性、業務停止、法令、費用への影響を評価。
3. **レビューと承認**：権限を持つ変更承認者・委員会等が判断。重要変更は職務分離や追加の承認を検討。
4. **計画・テスト**：変更手順、タイミング、事前バックアップ、検証基準、関係者への通知を準備。
5. **実装・デプロイ**：承認された範囲内で変更。実際の作業内容、担当者、時刻を記録。
6. **評価・検証**：機能・回帰・セキュリティの各テストで成功を確認。問題時は予め定義した条件でロールバック。
7. **クローズと記録更新**：変更結果、教訓、構成管理情報（CI・構成ベースライン・資産台帳等）を更新。

## 4. ITIL 4：変更実現（Change Enablement）

| 区分 | 意味 | 例 | 注意点 |
|---|---|---|---|
| **標準変更（Standard Change）** | 低リスク・繰返し可能で、事前承認された手順による変更 | 定型手順に沿った端末設定変更 | 毎回ゼロからの承認は通常不要。ただし手順・対象が事前承認の範囲内であること |

| 区分 | 意味 | 例 | 注意点 |
|---|---|---|---|
| **通常変更（Normal Change）** | 標準にも緊急にも該当せず、リスクに応じた評価・承認を要する | 重要サーバーの計画的アップグレード | 変更の重大性に応じて承認方法が変わる |
| **緊急変更（Emergency Change）** | 重大インシデント等に対応するため迅速な実施が必要 | 重大な悪用中の脆弱性への緊急対策 | 迅速化しても必要な承認・記録・事後レビューを省略しない |

**注意：** ITIL 4では「Change Enablement」がプラクティス名。過去版や一般的実務では「Change Management」という名称も広く使用。

## 5. リリースとデプロイメント

- **リリース管理（Release Management）**：新しい、または変更されたサービス・機能をユーザーが利用できる状態にすることを管理する。何をいつ使えるようにするか、期待価値や受入れを重視。
- **デプロイメント管理（Deployment Management）**：新規または変更済みのコンポーネントを、開発・テスト・本番など所定の環境へ移動・展開することを管理する。技術的な配置・展開を重視。

**例：** 新バージョンのアプリを本番サーバーに配置するのは「デプロイ」。機能フラグを切り替えてユーザーへ新機能を提供するのは「リリース」。両者の日時は一致するとは限らない。

### リリースパッケージ

複数の変更や修正を一つの単位（リリースパッケージ）として管理する場合がある。変更の整合性、テスト、バージョン、ロールバック、配布先を追跡できるようにする。

## 6. 関連フレームワーク・規格

| 名称 | 関連する視点 |
|---|---|
| **NIST SP 800-128** | 情報システムのセキュリティ重視の構成管理（Security-Focused Configuration Management）。変更管理・構成ベースラインとの関連を理解する。 |
| **ISO/IEC 27001:2013 Annex A.12.1.2** | 変更管理（旧版の管理策番号）。 |
| **ISO/IEC 27001:2022 Annex A 8.32** | 変更管理（2022年版での管理策番号）。旧版と混同しない。 |
| **ITIL 4 Change Enablement** | 標準・通常・緊急の変更の分類、リスクに応じた承認を扱う。 |
| **PRINCE2 / PMBOK** | プロジェクト計画・スコープ・変更要求を管理する観点。運用変更のITILと対象・目的に違いがある。 |

## 7. CISSP試験で押さえる判断軸

- **無断変更を防ぐ**：本番変更は原則、正式なプロセスと権限者の承認を経る。
- **緊急変更でも統制する**：実施を速めることと、承認・記録を放棄することは違う。
- **リスクと可用性の均衡**：変更によるセキュリティ向上だけでなく、停止・互換性・復旧可能性を評価する。
- **事前・事後をセットで考える**：テスト、バックアップ、ロールバック計画、実装結果の検証、記録更新が重要。
- **構成管理と連携**：承認変更の実施後にはCIやベースラインの情報を更新し、構成ドリフトを防ぐ。
- **技術とガバナンスを区別**：作業者の技術的判断だけで重大な業務停止を承認しない。

## 8. 記憶用まとめ

- **変更管理＝決める → 実施する → 確認する**
- **変更コントロール＝勝手に変えさせないための統制**
- **回帰テスト＝ほかの機能が壊れていないか確認**
- **デプロイ＝環境に配置、リリース＝ユーザーに利用可能化**
- **ITIL 4＝標準・通常・緊急**

## 確認問題

**Q1.** 緊急変更なら承認や記録をすべて省略してよいか？ → **いいえ。** 必要な統制を迅速化し、事後レビューも行う。

**Q2.** 本番へのソフトウェア配置と、ユーザーへの機能公開は常に同じか？ → **いいえ。** デプロイメントとリリースは異なる活動。

**Q3.** 変更後、変更対象以外の機能が壊れていないことを確認するテストは？ → **回帰テスト。**

**Q4.** CISSPで本番変更の際に重要な判断は？ → **業務影響・リスク・承認・検証・復旧手段を総合して管理すること。**

---

# CISSP Domain 7.10｜復旧戦略を実装する

> 学習範囲：バックアップ、代替拠点、可用性・レジリエンス、RAID、SAN/NAS。本文は教材の読み上げ内容を基に補足した復習ノート。具体的な復旧時間や製品機能は構成・契約で変わる。

## 1. 復旧戦略を考える軸

- **BCP**：事業を継続する計画。**DRP**：情報システムやITサービスを災害から復旧する計画。
- **RTO（Recovery Time Objective）**：許容する復旧までの目標時間。**RPO（Recovery Point Objective）**：どこまでデータ損失を許容するかを示す目標時点（時間幅）。
- **MTD / MAO**：業務停止を許容できる最大時間。一般にRTOはMTDを超えないように設計する。
- 技術を先に選ばず、**BIA→RTO/RPO→対策選定→テスト**の順に検討する。可用性、完全性、コスト、法令・保持要件のトレードオフを評価する。

## 2. バックアップの最小限の保護：3-2-1

**3** コピー（原本1+バックアップ2）、**2** 種類の媒体・保存技術、**1** コピーをオフサイトに置く。例：本番ディスク、別ストレージへのバックアップ、遠隔地のバックアップ。クラウドは選択肢の一つであり、権限・暗号化・地域・復元可能性を確認する。

- ランサムウェアに備えるには、従来の3-2-1に加えて**オフライン、イミュータブル（改変不能）、別認証境界**などの保護が有益。3-2-1だけでは攻撃から必ず守れるわけではない。
- **複製・同期 ≠ 独立バックアップ**：削除や暗号化も同期され得る。復元テストが欠かせない。

### バックアップのロケーション

| 場所 | 利点 | 注意点 |
|---|---|---|
| オンサイト | 高速な取得・復旧、低遅延 | 火災・洪水・侵入による共通障害 |
| オフサイト | 同時被災リスクを下げる | 転送・搬送時間、復旧時の回線、地理的距離 |
| クラウド BaaS | 容量の伸縮、遠隔保管、自動化 | CSPとの責任分界、転送費・取り出し費、帯域、鍵・認証の保護 |

### バックアップ方式

| 方式 | 保存するもの | 一般的な取得負荷 | 一般的な復元手順・注意点 |
|---|---|---|---|
| フル | 対象データ全量 | 大 | フルを復元。基準点になる |
| 差分（Differential） | **最後のフル**からの変更全部 | フルから日が経つと増加 | **フル＋復旧時点に最も近い差分** |
| 増分（Incremental） | **直前の対象バックアップ**からの変更 | 小 | **フル＋必要な増分チェーン**。途中の欠落が問題に |
| ジャーナリング | 更新処理のログ・履歴 | 連続的な記録負荷 | 基準データ＋整合したログで所望時点へ。DB等の方式に依存 |
| スナップショット | 特定時点の状態を参照・保持 | 短時間で作成できる場合が多い | 基盤に依存。原本と同じ障害ドメインにある場合は独立バックアップではない |
| CDP（Continuous Data Protection） | 変更を継続的に記録 | 継続的な負荷・容量 | 多数の時点に戻せ、RPOを小さくできる。保持・整合性を管理 |

**例：月曜フル、火曜・水曜・木曜の変更**：木曜時点へ差分方式で戻すなら月曜フル＋木曜差分。増分方式なら月曜フル＋火水木の増分（実装によって合成・最適化あり）。

### 世代管理と保護

- 世代数・保持期間・保管場所・暗号鍵・責任者を明確化。直前1世代だけでは、破損・誤削除を過去から復元できない可能性がある。
- バックアップの成功通知だけで安心せず、**定期的な復元テスト**、整合性・マルウェア検査、アクセス制御、監査ログを整える。
- データ保持・削除義務、個人情報、リーガルホールドの要件を確認する。

## 3. リカバリーサイト戦略

| 種類 | 状態・用途 | 復旧の傾向 | コスト感 |
|---|---|---|---|

| 種類 | 状態・用途 | 復旧の傾向 | コスト感 |
|---|---|---|---|
| ミラーサイト | 本番に近い構成・データを同期し迅速切替 | 非常に短い場合が多い | 非常に高い |
| ホットサイト | 稼働設備・ネットワーク・ソフトが準備済み | 分〜時間が目安 | 高い |
| ウォームサイト | 一部設備あり、データ更新や追加構成が必要 | 時間〜日が目安 | 中程度 |
| コールドサイト | 施設と最低限の基盤中心。機器・データ搬入が必要 | 日〜週以上の場合も | 比較的低い |
| モバイルサイト | 移動可能な設備・通信手段を搬入 | 調達・移動状況次第 | 条件次第 |
| クラウドDR | クラウド上へ待機・復旧・切替 | 構成（常時稼働／ウォーム／コールド）次第 | 従量・設計次第 |
| 共同運用協定（JOA）／覚書（MOU） | 他組織との相互支援・設備利用の取り決め | 相手方の能力・災害時の余力次第 | 契約次第 |

**注意**：教科書にある復旧時間は典型例であり、普遍的な保証値ではない。リカバリーサイトの**地理的分離**、同じ電力網・通信回線・災害域への依存、設備互換性、人員・アクセス権、演習を評価する。

### ミラーリングと複数処理サイト

- **ミラーリング**：状態・データを複製し同期する仕組み。誤操作や破損も複製され得るためバックアップの代わりではない。
- **複数処理サイト**：複数拠点で実処理を担う方式（active-active等）。負荷分散や拠点障害耐性に役立つが、複雑さ・整合性管理が課題。
- 両方を組み合わせられる。「ミラーだから必ずactive-passive」とは限らない。

## 4. システムレジリエンス・高可用性・QoS・フォールトトレランス

- **レジリエンス**：障害を受けても重要機能を維持・適応・回復する能力。
- **高可用性（HA）**：障害停止時間を短くする設計。
- **フォールトトレランス**：構成要素の故障が起きても必要機能を継続できる性質。HAより「無停止の継続」に焦点。
- **QoS**：帯域や優先順位などを制御してサービス品質を確保。可用性そのものを保証するわけではない。
- **予備部品**：重要部品の交換・修理用在庫を確保。予備があるだけでは交換時間ゼロではない。

### クラスタリング

| 構成 | 仕組み | 主な利点・課題 |
|---|---|---|
| Active-Active | 複数ノードが同時に処理 | 負荷分散・継続性。データ整合性、容量余力、スプリットブレイン対策が必要 |
| Active-Passive | 片方が通常稼働、待機側が障害時に昇格 | シンプルな切替設計が可能。切替遅延、待機資源コストあり |

**UPSと発電機**：UPSは瞬断や短時間停電に即応し、発電機の起動や安全停止まで橋渡しする。発電機は長時間の給電を担うが起動時間、燃料、保守に依存。両者は補完関係。

## 5. RAID（Redundant Array of Independent Disks）

RAIDは複数ディスクを束ね、**性能・冗長性・容量**のバランスを取る方式。**RAIDはバックアップではない**（削除・ランサムウェア・火災等に対する独立復元手段ではない）。以下は同容量ディスクを前提とした概念上の比較。N＝ディスク数、S＝1台の容量。

| レベル | 基本方式 | 概ね必要な台数 | 容量の目安 | 許容するディスク故障 | 覚えるポイント |
|---|---|---|---|---|---|
| RAID 0 | ストライピング（分散） | 2 | N×S | **0台** | 高速・容量効率100%、**冗長性なし** |
| RAID 1 | ミラーリング（複製） | 2 | 典型的な2台ミラーはS | 2台ミラーなら1台 | 容量を犠牲にデータ複製 |
| RAID 2 | ビット単位ストライピング＋ハミング符号 | 実装依存、多数 | 実装依存 | 符号設計依存 | 歴史的方式・現代ではほぼ使われない |
| RAID 3 | バイト単位ストライピング＋**専用パリティ** | 3 | (N−1)×S | 1台 | 小さなI/Oもディスク群に影響 |
| RAID 4 | ブロック単位ストライピング＋**専用パリティ** | 3 | (N−1)×S | 1台 | パリティディスクに書込集中 |
| RAID 5 | ブロック単位ストライピング＋**分散パリティ** | 3 | (N−1)×S | **1台** | 容量効率と冗長性の折衷。再構築時の負荷に注意 |
| RAID 6 | ブロック単位ストライピング＋**二重分散パリティ** | 4 | (N−2)×S | **2台** | RAID 5より故障耐性が高い |
| RAID 0+1（01） | **ストライプした集合をミラー** | 4 | 概ね総容量の半分 | 故障位置に依存 | 一方のストライプ集合が壊れると残りへ依存 |
| RAID 1+0（10） | **ミラーした組をストライプ** | 4 | 概ね総容量の半分 | **各ミラー組から1台ずつなら複数台も可** | 一般に01より故障組合せに強い |
| RAID 1+5（15） | **RAID 1のミラー組を構成要素としてRAID 5** | 6（2台ミラー×3組） | 6台例：2×S（約1/3） | **6台例：任意の2台は耐える。3台以上は故障位置による** | ミラー組の一方が故障しても継続し、1組全体の喪失もRAID 5のパリティで補う |

| レベル | 基本方式 | 概ね必要な台数 | 容量の目安 | 許容するディスク故障 | 覚えるポイント |
|---|---|---|---|---|---|
| RAID 5+1（51） | **RAID 5の集合をRAID 1で丸ごとミラー** | 6（3台RAID 5×2組） | 6台例：2×S（約1/3） | **6台例：任意の3台は耐える。4台以上も故障位置によっては可** | 片方のRAID 5集合が全滅しても、もう片方が動作可能なら継続 |

### RAID 10 vs RAID 01（4台の例）

- **RAID 10**：AとBがミラー、CとDがミラー。それら2組に分散する。AとCが壊れても残るが、AとBが同時に壊れると同一ミラー組が消失。
- **RAID 01**：AとBでストライプ集合、CとDで別ストライプ集合。その2集合をミラー。A故障でAB集合が使えなくなり、さらにCまたはDが故障すれば全体が失われる。
- 試験で押さえる順：**0＝高速だが保護なし、1＝複製、5＝パリティ1台耐性、6＝2台耐性、10＝ミラー→ストライプ**。

### RAID 15とRAID 51（複合RAID）【追加】

**RAID 15＝ミラーしたディスク組をRAID 5で束ねる／RAID 51＝RAID 5で作ったグループをミラーする。** 数字の並びによって下位の構成が異なる。どちらもミラーリングとパリティによる保護を重ねるため容量効率が低く、一般的なRAID 5・6・10ほど広く利用されていない。名称や対応方式はベンダー依存の場合があるため、製品の構成定義を優先する。

**6台の例（各ディスク容量S）**

- **RAID 15**：`[A1⇔A2]・[B1⇔B2]・[C1⇔C2]` の3つのミラー組を、RAID 5で束ねる。どの2台が故障しても保護されるが、例えばA1・A2とB1・B2の計4台が故障すると、RAID 5の構成要素が2組失われるため復旧不能。3台でも、故障箇所次第で可否が変わる。
- **RAID 51**：`RAID 5(A1,A2,A3) ⇔ RAID 5(B1,B2,B3)` の2組を丸ごとミラー。3台が故障しても、少なくともどちらか一方のRAID 5集合は正常または1台故障の状態にとどまる。一方で、A側2台・B側2台など両集合が各2台失うと復旧不能。A側3台・B側1台の計4台故障なら継続可能。

**注意：** 「何台故障まで耐えるか」は、常に保証される最小の耐性と、故障位置が好条件のときの最大値を区別する。RAID 15・51は特にこの違いが重要。どちらも**独立したバックアップの代わりにはならない**。

参考：［RAID 15/51の構造比較（講義資料）］(https://www.viser.edu.rs/uploads/2018/03/Predavanje%2008b%20-%20RAID%20napredne%20teme.pdf)、［Red Hat：複合RAIDの概要］(https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/4/html/introduction_to_system_administration/s2-storage-adv-raid)。

## 6. 集中データストレージ：SANとNAS

| 比較 | SAN（Storage Area Network） | NAS（Network Attached Storage） |
|---|---|---|
| 提供する単位 | **ブロックストレージ** | **ファイルストレージ** |

| 比較 | SAN（Storage Area Network） | NAS（Network Attached Storage） |
|---|---|---|
| よく使う通信 | Fibre Channel、iSCSI、NVMe-oFなど | SMB、NFSなど |
| --- | --- | --- |
| 利用者からの見え方 | サーバーにはディスク／LUNとして見える | ネットワーク上の共有フォルダーとして見える |
| --- | --- | --- |
| 典型用途 | DB、仮想化基盤、高性能な共有ブロック基盤 | ファイル共有、部門文書、バックアップ保存先 |
| --- | --- | --- |
| 注意点 | ネットワーク冗長化、LUNアクセス制御、容量管理、構成の複雑さ | 共有権限、認証、ランサムウェア対策、性能・可用性 |

**SAN＝Storageの専用・論理ネットワーク／ブロック、NAS＝Network上のファイル共有。**SANが必ず専用の物理回線というわけではない（IPベースSANもある）。NASの実体も内部でRAIDを利用でき、RAID・SAN・NASは異なるレイヤーの概念。

### CISSPでの選択例

- DBサーバーに共有ディスク相当の**ブロックI/O**が必要：SANを検討。
- 多数の従業員が共同文書を**ファイル単位**で共有：NASを検討。
- ディスク障害に耐えたい：RAIDなどの冗長化。ただし別のバックアップも必要。
- サイト喪失に備える：遠隔バックアップ・代替サイト・復旧演習を組み合わせる。

## 7. 重要比較・試験直前の確認

1. **差分 vs 増分**：前者は最後のフル以降、後者は直前のバックアップ以降。
2. **バックアップ vs RAID vs ミラー**：バックアップ＝過去時点への独立復元手段、RAID＝ディスク障害対策、ミラー＝現在状態の複製。目的が違う。
3. **RTO vs RPO**：止めてよい時間 vs 失ってよいデータの時間幅。
4. **ホット vs ウォーム vs コールド**：復旧の速さと待機コストは概ねトレードオフ。
5. **Active-Active vs Active-Passive**：同時処理 vs 待機・切替。
6. **RAID 5 vs 6**：1台故障まで vs 2台故障まで（通常の構成）。
7. **RAID 01 vs 10**：ストライプ集合をミラー vs ミラー集合をストライプ。
8. **SAN vs NAS**：ブロック vs ファイル。
9. もっとも重要なのは機器の名称より**BIAに基づく事業のRTO/RPOを満たし、実際にテストされた復旧能力。**

## 8. 確認問題

**Q1.** 月曜フル、以降毎日差分バックアップを取った。木曜時点への復旧に必要なのは？
**A.** 月曜フル＋木曜差分。

**Q2.** RAID 5（5台構成）で同時に2台故障した。通常、データの継続利用は保証される？
**A.** いいえ。通常のRAID 5は1台故障耐性。

**Q3.** RAID 10（4台）のディスク障害は必ず2台まで耐えられる？
**A.** いいえ。同一ミラー組の2台故障は致命的。異なる組の2台なら耐えられる。

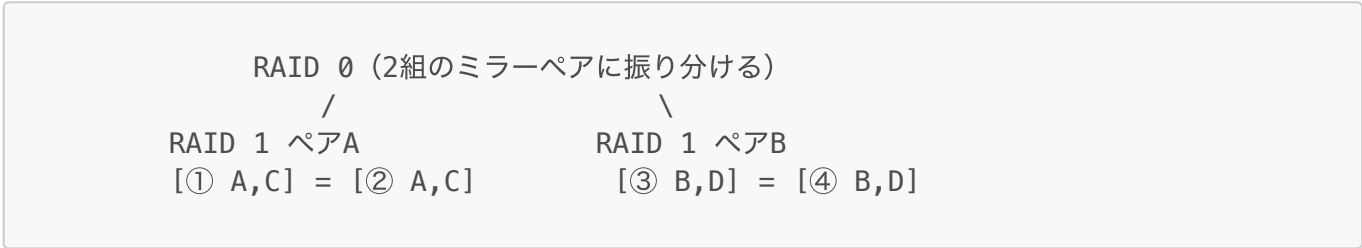
**Q4.** 同一ストレージ筐体内のスナップショットだけでオフサイトバックアップの代わりになる？
**A.** ならない。共通障害や侵害に巻き込まれる可能性がある。

**Q5.** ネットワーク共有フォルダを提供する技術として典型的なのは？
**A.** NAS（SMB/NFSなど）。

## 補足：RAID 10とRAID 01を4台構成で直感的に比較する

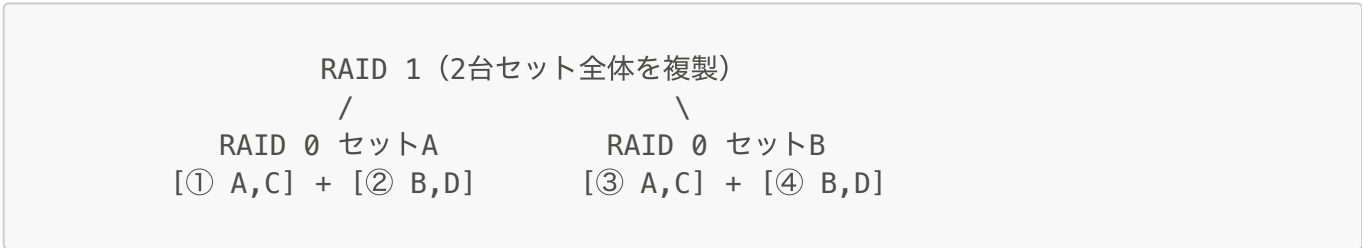
**どちらも4台の容量の半分を使ってデータを二重化できるが、「故障時にどのまとまりが失われるか」が違う。**
「10」は**ミラー（1）の組をストライプ（0）**、「01」は**ストライプ（0）の組をミラー（1）**。

**RAID 10：まず2台ずつ複製して、そのペア間でデータを分ける**




①と②が同じ内容、③と④が同じ内容。①と③が同時故障しても②と④が残るので動作可能。一方、①と②が両方壊れるとA,Cが失われ、動作不能。

**RAID 01：まず2台に分散して、その「2台セット」を丸ごと複製する**




①と②を**合わせて一つのデータセット**と捉え、それと同じものを③と④のセットに作る。①が故障するとセットA全体が使えなくなり、残るセットBに依存する。その状態で③も故障するとセットBも使えなくなるため動作不能。逆に①と②が故障してもセットBが残れば動作可能。

| 比較 | RAID 10 | RAID 01 |
|---|---|---|
| 基本単位 | 2台の**ミラーペア** | 2台の**ストライプセット** |
| 先に作るもの | RAID 1 | RAID 0 |
| 後から組み合わせる方式 | RAID 0 | RAID 1 |
| ①と③が故障 | **動作可能**（②と④が残る） | **動作不能**（両セットが壊れる） |
| ①と②が故障 | **動作不能**（同一ペア全滅） | **動作可能**（③④のセットが残る） |

| 比較 | RAID 10 | RAID 01 |
|---|---|---|
| 試験でのポイント | 別ペアの故障なら複数台でも耐えられる | 両ストライプセットに故障が分散すると危険 |

※上記の①〜④の番号は理解用の例。同じディスク番号でも、**グループの組み方**によって故障の判定が変わる。RAID 10は一般にRAID 01より再構築・故障耐性の面で有利とされる。どちらもバックアップの代わりにはならない。

---

# CISSP Domain 7.11｜災害復旧プロセスを実装する

> 学習用統合ノート。**「教材読み上げ内容」**を軸に整理し、具体例や試験対策上の説明は**「補足」**として区別する。

## 1. この章の全体像

大規模な障害や災害が発生した際、**どの状況でBC/DR対応を始めるかを判断し、適切な権限で発動し、関係者へ連絡し、被害と証拠を評価して、業務を復元し、訓練と教訓につなげる**ためのプロセスを扱う。

**流れ：発動基準の設定 → 判断・指揮 → 社内外コミュニケーション → アセスメント → 復元 → 訓練・アウェアネス → 教訓・改善。**

| 概念 | 主な目的 | 例 |
|---|---|---|
| BC（Business Continuity） | 重要業務を継続・再開できる状態を維持 | 代替手段で顧客対応を継続 |
| DR（Disaster Recovery） | 障害後のITシステム・データ等を復旧 | 代替サイトでシステムを再起動 |
| BCDR | 事業継続とIT復旧を一体的に計画・実施 | データセンター停止時の代替サイト移行 |

## 2. 対応措置を開始する基準と判断体制

### 教材読み上げ内容

- BCDRを開始する**認められた要因・発動基準**をあらかじめ定める。
- 意思決定機関が**適時に正しい判断**を下せるよう、十分な情報を届ける**情報チェーン**を整える。
- どのような状況でも自動的に全面DRへ移行すればよいわけではなく、状況の評価と権限に基づく判断が必要。

### 補足：判断に使う情報の具体例

| 判断材料 | 具体例 | 何を判断するか |
|---|---|---|
| 被害範囲 | 単一サーバー停止／データセンター全体停止 | 局所復旧か、全社DR発動か |
| 業務影響 | 決済・受注が停止している | 優先して復旧する業務 |
| 停止見込み | 通常復旧までの予測時間 | 代替サイトへの切替要否 |
| RTO・RPO | 目標復旧時間・許容データ損失 | 選択した復旧策の適合性 |

| 判断材料 | 具体例 | 何を判断するか |
|---|---|---|
| 安全性 | 火災、浸水、感電等の危険 | 人命保護、立入禁止・避難 |
| 法的・契約上の義務 | 報告義務、証拠保全 | 関係部門の参加や報告要否 |

**試験対策：** 原則として、技術担当が独断で全社的な業務停止・DR発動を決定するのではなく、**事前に定義された権限者**の判断に必要な情報を届ける。

# 3. 人員・役割・責任

教材読み上げ内容

- **IT管理者・アーキテクト・技術者**：不測の事態に必要なシステムの技術的対応。
- **セキュリティ専門家**：脅威・侵害・コントロール・証拠保全等についての知見と経験。
- **法務**：法令、証拠、契約、法的対応。
- **人事**：従業員の安全、勤務・労務上の調整。
- **財務・会計**：損失把握、資金調達、財務上の影響。
- **広報・コミュニケーション担当**：公式な情報発信と外部説明。
- **マネジメント**：権限に基づく判断、優先順位、資源配分。

補足：RACIによる役割の整理例

**R（Responsible）＝実行、A（Accountable）＝最終的な説明責任・決裁、C（Consulted）＝相談先、I（Informed）＝情報共有先。**

例えば「代替拠点への切替」なら、IT復旧チームがR、所定の危機管理責任者がA、セキュリティ・法務がC、影響を受ける業務部門がIとなる構成が考えられる。ただし実際の権限設計は組織の計画に依存する。

# 4. コミュニケーション

## 4.1 社内連絡

**教材読み上げ内容：** 情報をタイムリーに必要な相手へ共有できるよう、組織のポリシーと実践手順を事前に整備する。

**補足：** 連絡先一覧、代替通信手段、緊急連絡ツリー、報告頻度、機密性分類、意思決定記録を準備する。社内チャットが停止する場合に備え、別経路も検討する。

## 4.2 外部連絡

**教材読み上げ内容：** 連絡先には、法執行機関・警察・消防・医療支援などの第一対応者、規制当局、一般大衆、ビジネスパートナーなどが含まれる。

- **声明の統一**：外部説明に不一致が生じないようにする。
- **訓練されたコミュニケーション専門家の活用**：正確で適切な説明を支援する。
- **進行中の状況への対応**：確定情報と未確認情報を分け、事態の変化に応じて更新する。

**補足：** 「誰が、何を、いつ、どの経路で、公表・通知するか」を発災前に決める。憶測や機微情報を不用意に開示しない。規制報告は**適用される法令・契約上の期限**を確認する。

# 5. アセスメント（評価）

## 教材読み上げ内容

災害やインシデント後の評価は、復旧判断だけでなく、次の目的でも重要となる。

1. **刑事訴訟**：犯罪に関連する事実や証拠。
2. **民事訴訟**：損害・過失・契約違反などを巡る説明。
3. **投資家への報告**：財務・事業への重要な影響を説明。
4. **規制当局への情報提供**：求められる事実と根拠を提出。

## 補足：記録すべき項目の例

- 発生・検知・判断・復旧の**時刻と時系列**。
- 影響を受けた業務、システム、データ、利用者。
- 被害規模と損失見込み。
- 実施した判断、承認者、対応、結果。
- 証拠の所在・完全性・取扱履歴（**Chain of Custody**）。

**注意：** 業務の早期復旧と証拠保全は衝突する場合がある。調査担当・法務等と協調して対応する。

# 6. 復元（Restore / Reconstitution）

## 教材読み上げ内容

目標は、安全に運用可能な状態へ戻すこと。方法として、

- **元のプライマリー運用サイトへ復帰する。**
- **新たなプライマリー運用サイトを構築する。**
- **データを実運用環境にリストアする。** などがある。

## 補足：復旧手順のイメージ

1. 現場・システムの安全性、脅威の除去、復旧先の利用可能性を確認。
2. 選択した復旧先の設備・ネットワーク・認証基盤を整備。
3. バックアップからデータ・システムを復元、必要に応じて切替。
4. **データ完全性、業務機能、セキュリティ統制**を確認。
5. 権限者の判断で段階的に業務を再開し、利用者へ周知。
6. 代替サイト利用後の本番復帰（**Failback**）も計画・検証する。

**重要：** 「システムが起動した」ことと「業務が安全に再開できる」ことは同義ではない。RTO・RPOと業務依存関係を確認する。

# 7. トレーニングとアウェアネス

## 教材読み上げ内容

非常時に適切な行動ができるよう、日頃からトレーニングとアウェアネス活動を行う。

## 補足：対象と具体例

| 対象 | 訓練例 |
| --- | --- |
| 経営陣・危機管理責任者 | 発動判断、重大業務の優先順位、対外発表の承認 |
| IT・DR担当 | 復元、代替サイト切替、復帰手順 |
| セキュリティ・法務 | 証拠保全、報告義務、封じ込めとの調整 |
| 全従業員 | 避難、連絡手順、代替業務手順 |

机上演習・シミュレーション・並行稼働・実切替試験などを、業務影響とリスクを踏まえて段階的に実施する。

## 8. 復旧からの教訓（Lessons Learned）

### 教材読み上げ内容

復旧後に得られた教訓を振り返り、今後のBCDR能力に反映する。

### 補足：改善の具体例

- 想定RTOと実績時間の差を分析。
- 連絡網・判断・権限のボトルネックを修正。
- 復元失敗の原因、バックアップ不足、依存関係の見落としを改善。
- BCP/DRP・ランブック・連絡先・訓練計画を更新。
- 改善項目の担当者と期限を決め、実施状況を追跡する。

## 9. CISSP直前暗記表

| 設問の状況 | 考えるべきこと |
| --- | --- |
| DRを始めるべきか | **事前の発動基準・影響評価・権限者の判断** |
| 意思決定者に状況が伝わらない | **情報チェーンと報告経路** |
| 技術担当が勝手に業務停止を決定 | **役割・権限・エスカレーションを確認** |
| 外部への発表内容が部署ごとに異なる | **公式な統一声明・広報・法務** |
| 災害の記録が後から必要になる | **アセスメント、証拠保全、文書化** |
| 代替拠点から元の拠点に戻す | **Failback（本番復帰）** |
| サーバーは動くが業務が使えない | **業務機能の検証と依存関係の確認** |
| 次回の災害に強くしたい | **教訓・改善・再訓練** |

### 最重要の一文

**BCDRは技術的な復旧作業だけでなく、発動権限・人員・連絡・法的証拠・業務再開・継続的改善までを含む組織的な対応プロセス。**

---

# 7.12｜災害復旧計画をテストする

---

> 読み上げ内容：リードスルー、机上演習、ウォークスルー、シミュレーション、パラレル演習、完全中断、コミュニケーション、監査。以下、詳細は試験用補足。

## 1. なぜDRPをテストするのか

災害復旧計画（DRP）が**実際に機能するか**、手順、担当、データ復元、バックアップ、切替、通信、依存関係、**RTO/RPO**が現実的かを実証する。紙の上で整っていても実行できなければ有効な計画とはいえない。演習の方式は**試験効果・業務影響・費用・安全性**のトレードオフで選ぶ。

## 2. 演習方式の比較

| 手法 | 具体的な取り組み | 本番影響 | 検証できること・限界 |
|---|---|---|---|
| **リードスルー（Read-through）** | 担当者がDRP・連絡網・復元手順を順番に読み、誤記や矛盾を洗い出す | 小 | 計画内容の理解と欠落の確認。実際に機器が動くかは未検証 |
| **机上演習（Tabletop）** | モデレーターが「本番センター停電」等のシナリオを提示し、関係者が対応を議論する | 小 | 意思決定、責任分担、連絡手順、優先順位を確認。実機検証は弱い |
| **ウォークスルー（Walkthrough）** | 担当者が手順や現場の経路を順にたどり、行動・資材・権限を確認する | 小〜中 | 手順の具体性・人員・現場動線を検証。実運用の性能保証ではない |
| **シミュレーション（Simulation）** | 模擬障害・訓練環境で、実際に近い手順・判断を練習する | 小〜中 | タイミング・連携・判断の確認。再現条件と現実との差がある |
| **パラレルテスト（Parallel）** | **本番稼働を維持したまま**代替サイトで復元・処理を並行実行する | 中 | 代替サイトの性能・整合性・復元を実証。本番トラフィック切替は完全には検証しない場合がある |
| **完全中断・フルインタラプション（Full Interruption）** | 本番側を停止し、代替サイトに実際に切り替えて運用する | **非常に大きい** | 実際の切替・依存関係・RTO等を強く検証できるが業務リスクが高い |

**試験注意**：リードスルーと机上演習は資料により重なって説明される。名称より「**実システムを切り替えるか、議論するだけか**」で見分ける。フルインタラプションは安易に実施せず、承認と慎重な計画が必要。

### 机上演習の例

モデレーター：「平日15時にプライマリー拠点の電力喪失。復旧見込み8時間。RTOは2時間です」→ 危機管理責任者が発動判断→ITが代替拠点の準備状況を説明→広報・法務が通知ルールを確認→改善点を記録。**実機切替をしない**点が特徴。

## 3. コミュニケーションの試験

- **誰に・いつ・どう伝えるか**：社員、経営陣、取引先、顧客、規制当局、第一対応者に対する情報経路と代行者。
- **代替通信**：メール・チャット・電話網が障害時に使えない場合の代替手段と連絡網更新。
- **声明の一貫性**：広報・法務承認を経た公式発表。事実、推測、未確認情報を区別。

- **測定例**：連絡到達率、発動承認時間、代替サイト起動時間、RTO/RPO達成、復元精度。

ISO/IEC 27001に基づくISMSの監査等では、組織に適用される事業継続関連管理策の**設計・実装・有効性を示す記録**が重要になる。監査で一律に「必ず完全中断試験を実施」と要求されるわけではなく、リスク、文書化した計画、適用管理策が評価される。

### 4. 演習後の改善

**目的・成功条件の定義 → 安全な準備・承認 → 実施・計測 → 実績とRTO/RPOとの差分確認 → 教訓 → 計画改訂・再訓練。**

**CISSP暗記**：「読む／話し合う／歩く／模擬する／並行で動かす／本番を切り替える」の順に実証性が高まりやすい一方、費用とリスクも概ね増加。

---

## 7.13｜事業継続計画及び演習に参加する

> 読み上げ内容：BCP、NIST SP 800-34、ISO 22301、BIA、MTD/RTO/RPO、計画メンテナンス、年次・変更時演習。

### 1. BCP / DRP / BCM の関係

- **BCP（Business Continuity Plan）**：災害・障害の最中でも重要業務を許容範囲で継続し、順次再開するための計画。人・拠点・調達・サプライヤー・業務手順を含む。
- **DRP（Disaster Recovery Plan）**：IT・通信・データ・システムの復旧計画。BCPを支える。
- **BCM（Business Continuity Management）**：BCPの策定・演習・見直しを含む継続的なマネジメント。
- **NIST SP 800-34 Rev.1**：*Contingency Planning Guide for Federal Information Systems*。情報システムの緊急時計画、BIA、復旧戦略、計画のテスト・訓練・演習に関連。
- **ISO 22301**：Business Continuity Management System（BCMS）の**要求事項**を定める国際規格。組織的な事業継続能力を管理・改善する。

### 2. BIA（Business Impact Analysis：事業影響度分析）を詳しく

**BIA**は、業務が中断した場合の影響（時間、金銭、規制、顧客、安全、信用など）を評価し、**重要業務・依存関係・復旧優先順位・許容停止時間・データ損失許容度**を明らかにする活動。何を守るべきかの優先度を決めるため、復旧技術の選定よりも前に行う。

#### BIAの進め方

1. 業務プロセスと**業務オーナー**を特定する。
2. 業務停止による損失を**時間経過別**（2時間後／1日後／1週間後など）に評価する。
3. 他システム、認証基盤、データ、人員、外部事業者への**依存関係**を把握する。
4. MTD、RTO、RPO等を設定・合意し、業務復旧優先順位を決める。
5. 代替手順・バックアップ・人員体制・サイト要件を検討し、定期レビューする。

#### MTD / RTO / RPO / WRT 比較（特に重要）

| 指標 | 意味・イメージ | 例 |
|---|---|---|

| 指標 | 意味・イメージ | 例 |
|---|---|---|
| **MTD（Maximum Tolerable Downtime）／MAO（Maximum Acceptable Outage）** | 業務停止が耐えられる**最大時間** | 受注業務が6時間以上止まると許容できない |
| **RTO（Recovery Time Objective）** | サービス・システムを復旧する**目標時間** | 障害から4時間以内に受注システムを復旧 |
| **RPO（Recovery Point Objective）** | 許容されるデータ損失の**時間幅／復旧時点** | 最大15分前の状態まで復旧できればよい |
| **WRT（Work Recovery Time）** | IT復旧後に業務検証・入力再処理・業務再開までに必要な時間 | IT復旧後、注文データ照合に1時間 |

**補足**：典型的には **RTO + WRT ≤ MTD** を満たすよう設計する。RTOは時間、RPOは**データの復旧時点に関する時間幅**であり「何時間で復旧するか」ではない。

**例**：受注業務のMTD＝6時間、RTO＝4時間、WRT＝1時間、RPO＝15分。4時間でITシステムを再起動し、1時間でデータ照合・業務立上げができ、合計5時間で業務再開。直近15分のデータは失われる可能性がある。重要な依存先（認証基盤やネットワーク）の復旧時間も考慮。

**試験トラップ**：「ITシステムは稼働している」だけではBCP達成ではない。**業務全体が再開**し、MTD内に収まるかを見る。

## 3. BCPのメンテナンス

- 組織改編、人事異動、システム更新、外部委託変更、重要業務の新設、法規変更に合わせて改訂。
- バージョン・所有者・承認日、配布先、連絡網、代替手段、機密性、アクセス可能な保管場所を管理。
- テストで発見した欠陥・教訓・RTO/RPO未達を是正。更新だけでなく**再演習で検証**する。

## 4. BCP演習・テスト

教材では**通常、少なくとも年1回程度、また重大な変更時にも演習**することを目安としている。ただし「すべての法令・ISO 22301が一律に年1回を必須と定める」と一般化しない。頻度は規制、契約、影響度、組織ポリシーに従う。

- 机上演習：意思決定・連絡・業務優先順位を確認。
- 業務代替のシミュレーション：手作業受注、外部コールセンターへの切替など。
- IT復旧テスト：バックアップ復元、代替システム運用、切戻しなど。
- 事業部門も参加し、重要な手順の実行可能性・人員・外部委託先との連携を確認。

**CISSP判断**：BCPは経営・業務主導、DRPはITの実装を支える。**BIA→戦略→計画→訓練／テスト→維持改善**の循環を覚える。

---

# 7.14｜物理セキュリティを実装・管理する

> 読み上げ内容：境界・内部コントロール、カード・CCTV、BMS、音響・赤外線・ビーム・PIR・REX・デュアル技術センサー。詳細は標準的な物理セキュリティの補足。

## 1. 境界 vs 内部の物理統制

- **境界セキュリティ（Perimeter Security）**：敷地・建物・保護区域の**入口や外周**で不正侵入を抑止・阻止・検知する。外周フェンス、車両ゲート、門扉、警備員、照明、カメラ、受付、入館カードなど。
- **内部セキュリティ（Internal Security）**：保護区域の**内側**で横移動・不正入室・設備被害を制限し、異常を検知する。サーバールームの扉、ラック施錠、室内カメラ、環境センサー、入退室履歴など。
- 境界は敷地外周だけでなく**サーバールーム扉のような内側の保護区域の境界**にも設けられる。カードリーダーやCCTVは**設置場所と目的**によって両方に使う。

**例**：敷地ゲート→ビル入館→フロア入室→サーバールーム入室→ラック開錠、という**多層防御（Defense in Depth）**で考える。

## 2. 境界コントロールの具体例

| 統制 | 役割 | 留意点 |
|---|---|---|
| フェンス・壁・門扉 | 物理的に侵入しにくくする（予防・抑止） | 迂回・乗越え・破壊を防ぎ切れない |
| 車止め（Bollard） | 車両の突入を防ぐ | 必要な強度・位置・アクセス性 |
| 警備員・受付・訪問者登録 | 身元確認、付添い、異常対応 | 訓練と承認済みの入館ルール |
| カードリーダー・バッジ | 資格情報で入室を制御・記録 | カード紛失・貸与・共連れへの対策 |
| マントラップ／セキュリティゲート | 一度に通行する人数を制御し共連れを抑制 | 避難動線・アクセシビリティへの配慮 |
| CCTV・照明・警報 | 可視化、抑止、事後調査 | 死角・録画保存・プライバシー・電力 |

## 3. 内部モニタリングツール・センサー

| 種類 | 何を検知・制御するか | 設置例・注意点 |
|---|---|---|
| **カードリーダー** | 認証資格情報による入室制御・ログ | サーバールーム入口。多要素化・共連れ防止を検討 |
| **BMS（Building Management System）** | 建物設備（空調、電力、換気等）を集中監視・制御 | 温湿度・電力の異常。管理ネットワークの保護が重要 |
| **音響センサー** | ガラス破壊、異常音等の音響信号を検知 | 窓・保管室。騒音による誤警報 |
| **赤外線センサー** | 赤外線を使った侵入・移動等の検知方式の総称 | 能動・受動で仕組みが異なる |
| **リニアビーム（Active IR Beam）** | 発光器と受光器の**赤外線ビーム遮断**を検知 | 廊下や入口。遮蔽物・光軸ずれ等に注意 |
| **PIR（Passive Infrared）** | 人体等の**熱赤外線の変化**を受動的に検知 | 室内の動体検知。温度条件・設置角度に注意 |

| 種類 | 何を検知・制御するか | 設置例・注意点 |
|---|---|---|
| **REX（Request to Exit：退出要求）** | 退出時の操作・接近を検知し、電気錠の解錠要求 | 退出側扉。防犯と消防・緊急避難の両立 |
| **デュアルテクノロジーセンサー** | 例：PIRとマイクロ波の**異なる検知原理を組合せ** | 両方の条件を利用して誤報低減を図る構成。製品方式による |
| **CCTV** | 動画監視、侵入・異常の記録 | 監視者・保存期間・死角・利用規程 |

**区別**：能動赤外線ビームは**光線が遮られたか**、PIRは**熱変化が動いたか**。REXは単なる防犯センサーではなく、**安全な退出を可能にする制御要素**。

## 4. CISSPでの物理セキュリティ判断

1. **人命・避難の安全が最優先**：入室制限を厳しくしすぎて火災時の退出を妨げてはいけない。Fail Safe/Fail Secureは設置箇所の安全・脅威・法規で選ぶ。
2. **抑止（Deterrent）／予防（Preventive）／検知（Detective）／対応**を層別に配備する。
3. **共連れ（Tailgating/Piggybacking）**やカード貸借を監視する。バッジ認証のみで本人性が完全保証されるわけではない。
4. 監視映像・入退室ログを適切に保護し、保持・プライバシー・時刻同期・証拠利用を考える。
5. BMSやネット接続カメラ等はITの攻撃対象にもなるため、ネットワーク分離、認証、アップデートが必要。

**覚え方**：**外周で入らせない／内部で広げさせない／異常を見つける／人を安全に避難させる。**

---

# 7.15｜人員の安全とセキュリティに関する懸念

> 読み上げ内容：旅行・出張、脅迫、訓練・認識、2FA、ソーシャルメディア、内部者脅威、緊急事態管理、MDM。以下に例と試験判断を補う。

## 1. 出張・旅行・リモートワーク時の保護

| 観点 | 具体的な対策 | CISSPの意図 |
|---|---|---|
| **不要な情報を持ち出さない** | 必要最小限のデータ・端末だけ携行。可能なら一時端末・仮想デスクトップ | 盗難・押収時の影響を最小化 |
| **携行する場合の保護** | 端末暗号化、MFA、画面ロック、バックアップ、最小権限 | 機密性・可用性の確保 |
| **安全なリモートアクセス** | 承認済みVPN／ZTNA、MFA、MDM、端末ヘルスチェック | 不審なWi-Fiや端末乗っ取りへの対策 |
| **法域・国境** | 渡航先の暗号利用・データ移転・検査・持込規制を確認 | 国内ルールがそのまま通用するとは限らない |
| **人員の保護** | 緊急連絡先、現地の安全情報、所在地に応じた支援計画 | 人命・健康を優先 |

| 観点 | 具体的な対策 | CISSPの意図 |
| --- | --- | --- |
| **コンディション監視** | 長時間勤務・時差・移動リスクに配慮し状況確認 | 疲労・事故・判断ミスを減らす |

**例**：重要顧客データを大量に保存したノートPCを海外に持っていくより、最小限の情報だけを扱う一時端末と安全なリモートアクセスを組み合わせる方が、持出し時の漏洩リスクを下げやすい。

## 2. 脅迫（Duress）と通報

**脅迫・強要**を受けた従業員が、自身と周囲の安全を確保しながら組織へ報告・支援要請できる経路を用意する。例：警備・人事・セキュリティへの緊急連絡、指定の合図やデュレスコード等（必要な環境に限る）。**危険が差し迫る場合は人命・身体の安全を優先**し、勇敢な抵抗を求めない。

## 3. セキュリティトレーニングとアウェアネス

- 渡航地域・施設別のリスクオリエンテーション。
- 緊急時の避難・連絡・インシデント報告手順。
- ユーザーが検知・報告・初動で果たす役割。
- フィッシング、標的型メール、なりすまし、脅迫、端末盗難等の**個人を狙った攻撃**への対応。
- **Awareness（気づき）**は「何を警戒すべきかを知る」、**Training（訓練）**は「具体的な対応を実行できる」、Education（教育）は「原理や専門知識を学ぶ」という観点で区別。

## 4. 二要素認証（2FA）／多要素認証（MFA）

**2FAは異なる種類の認証要素を二つ組み合わせること**。例：パスワード（知識）＋セキュリティキー（所持）、端末＋生体認証。**パスワード＋秘密の質問**は知識要素が二つであり、原則として2FAではない。

- 要素：**知識（Something you know）／所持（Something you have）／生体・特性（Something you are）**。
- フィッシング耐性の高いFIDO2/WebAuthn等の選択肢を考慮。SMS OTP等の方式にはSIMスワップ・フィッシング等のリスク。
- MFA導入後も紛失端末、リカバリー経路、セッション管理、特権アクセスの保護を考える。

## 5. ソーシャルメディア

- 業務内容、旅程、施設の写真、社員情報、バッジ、機密文書、位置情報などの公開範囲を制御。
- 攻撃者の**OSINT、標的型フィッシング、なりすまし、ソーシャルエンジニアリング**に利用され得る。
- 私生活・プライバシーを尊重しつつ、企業情報の扱いに関する周知・ポリシーを作る。

## 6. 内部者脅威（Insider Threat）

- 悪意ある従業員・委託先だけでなく、**不注意、誤操作、侵害された正規アカウント**も考える。
- 最小権限・Need-to-Know、SoD、PAM、ログ・UEBA、DLP、教育、ジョブローテーション、強制休暇、JML（入社・異動・退職）の権限管理が有効。
- **監視は適法性と必要性を満たし、根拠なく個人を断定・処分しない**。

## 7. 緊急事態管理（Emergency Management）

- **人の生命・健康・安全を最優先**し、避難、安否確認、初動対応者との連携、救助を計画する。

- 火災検知（煙・熱センサー）、警報、スプリンクラー等の抑制設備、避難路、非常口、集合場所、AED・救急支援、建物の安全設備。
- 火災時の**出入口の解除・避難の安全**と不正侵入対策を調整。環境保護装置は人間への危険性を評価して選ぶ。
- 警察、消防、救急、ビル管理、規制当局・地域関係者との連絡・役割を事前に定める。

## 8. MDM（Mobile Device Management）とUEM

**MDM**はスマートフォン・タブレット等の端末を組織のポリシーに沿って管理する仕組み。登録、パスコード、端末暗号化、OS更新、証明書・Wi-Fi/VPN設定、アプリ制限、紛失時のロック／ワイプ、準拠状況の確認など。**UEM**はPC等も含め統合して管理する枠組み。

- **BYOD**では個人データと業務データの分離（仕事用コンテナ等）、プライバシー、退職時の**企業データだけの選択的ワイプ**を検討。
- リモートワイプは端末がオフラインだと即時実行できない場合があり、事前の暗号化・アクセス失効が重要。

## 9. CISSPの最優先原則

1. **人命・安全を最優先**し、その次に業務・データ・機器を考える。
2. 移動時は**データ最小化**。暗号化だけで不要な持ち出しが正当化されるわけではない。
3. 人的対策（教育・役割・報告）と技術（MFA・MDM・DLP）を組み合わせる。
4. **内部者＝必ず悪意あり、UEBA異常＝確定した不正**とは考えない。
5. セキュリティと従業員の権利・プライバシーを両立させる。

---

# 運用・更新履歴

| 日付 | 更新内容 |
|---|---|
| 2026-10-27 | 添付ノート7.1〜7.2、7.4〜7.7、7.9〜7.11を原則全文統合。会話の7.3・7.8を再構成、7.12〜7.15を新規整理。 |

**以後の更新方法**：この**1ファイル全体を更新**する。新しく解説した内容を追加する際も、既存の章と表を削除せず、目次・更新履歴を改訂して**全文を毎回ダウンロードできる形で提供**する。